



macOS Security Compliance

macOS 26.0

diwai.org Domain Controller — Phase 1 Hardening

Tahoe Guidance, Revision 2.0 (2025-12-18)

Table of Contents

1. Foreword	1
2. Scope	2
3. Authors	3
4. Acronyms and Definitions	4
5. Applicable Documents	6
5.1. Government Documents	6
5.2. Non-Government Documents	6
6. iCloud	7
6.1. Disable iCloud Address Book	7
6.2. Disable the System Setting for Apple ID	8
6.3. Disable iCloud Bookmarks	8
6.4. Disable the iCloud Calendar Services	9
6.5. Disable iCloud Document Sync	10
6.6. Disable the iCloud Freeform Services	11
6.7. Disable iCloud Game Center	11
6.8. Disable iCloud Keychain Sync	12
6.9. Disable iCloud Mail	13
6.10. Disable iCloud Notes	14
6.11. Disable iCloud Photo Library	15
6.12. Disable iCloud Private Relay	15
6.13. Disable iCloud Reminders	16
6.14. Disable iCloud Desktop and Document Folder Sync	17
7. Auditing	19
7.1. Configure Audit Log Files to Not Contain Access Control Lists	19
7.2. Configure Audit Log Folder to Not Contain Access Control Lists	19
7.3. Enable Security Auditing	20
7.4. Configure System to Shut Down Upon Audit Failure	21
7.5. Configure Audit Log Files Group to Wheel	22
7.6. Configure Audit Log Files to Mode 440 or Less Permissive	23
7.7. Configure Audit Log Files to be Owned by Root	23
7.8. Configure System to Audit All Authorization and Authentication Events	24
7.9. Configure System to Audit All Administrative Action Events	25
7.10. Configure System to Audit All Failed Program Execution on the System	26
7.11. Configure System to Audit All Failed Change of Object Attributes	27
7.12. Configure System to Audit All Failed Read Actions on the System	28
7.13. Configure System to Audit All Failed Write Actions on the System	29
7.14. Configure System to Audit All Log In and Log Out Events	30
7.15. Configure Audit Log Folders Group to Wheel	31

7.16. Configure Audit Log Folders to be Owned by Root	31
7.17. Configure Audit Log Folders to Mode 700 or Less Permissive	32
7.18. Configure Audit Retention to 7d	33
7.19. Configure Audit Failure Notification	33
8. macOS	35
8.1. Disable AirDrop	35
8.2. Disable Apple ID Setup during Setup Assistant	35
8.3. Enable Authenticated Root	36
8.4. Disable Bonjour Multicast	37
8.5. Disable Burn Support	38
8.6. Disable Installation of Configuration Profiles through the User Interface	39
8.7. Disable Dictation	39
8.8. Disable Erase Content and Settings	40
8.9. Disable FileVault Automatic Login	41
8.10. Control Connections to Other Systems via a Deny-All and Allow-by-Exception Firewall Policy	42
8.11. Enable Gatekeeper	42
8.12. Disable Genmoji AI Creation	43
8.13. Disable Handoff	44
8.14. Secure User's Home Folders	45
8.15. Disable the Built-in Web Server	45
8.16. Disable iCloud Storage Setup during Setup Assistant	46
8.17. Disable Apple Intelligence Image Playground	47
8.18. Disable iPhone Mirroring	48
8.19. Disable Infrared (IR) support	48
8.20. Prevent AdminHostInfo from Being Available at Login Window	49
8.21. Disable Apple Intelligence Mail Smart Replies	50
8.22. Disable Apple Intelligence Mail Summary	51
8.23. Disable Network File System Service	52
8.24. Disable Apple Intelligence Notes Transcription	52
8.25. Disable Apple Intelligence Notes Transcription Summary	53
8.26. Enforce On Device Dictation	54
8.27. Disable Proximity Based Password Sharing Requests	55
8.28. Disable Password Sharing	55
8.29. Disable Photos Enhanced Visual Search	56
8.30. Display Policy Banner at Login Window	57
8.31. Display Policy Banner at Remote Login	58
8.32. Enforce SSH to Display Policy Banner	60
8.33. Disable Privacy Setup Services During Setup Assistant	61
8.34. Enforce Rapid Security Response Mechanism	62
8.35. Disable User Ability from Being Able to Undo Rapid Security Responses	62

8.36. Enable Recovery Lock	63
8.37. Disable Root Login	64
8.38. Disable Apple Intelligence Safari Reader Summary	64
8.39. Enforce Screen Saver at Login Window	65
8.40. Ensure System Integrity Protection is Enabled	66
8.41. Disable Siri Setup during Setup Assistant	67
8.42. Disable Apple Intelligence During Setup Assistant	68
8.43. Disable Screen Time Prompt During Setup Assistant	68
8.44. Disable Unlock with Apple Watch During Setup Assistant	69
8.45. Limit SSH to FIPS Compliant Connections	70
8.46. Set SSH Active Server Alive Maximum to 0	72
8.47. Configure SSH ServerAliveInterval option set to 900	74
8.48. Configure SSHD Channel Timeout to session:*=900	75
8.49. Configure SSHD ClientAliveCountMax to 0	76
8.50. Configure SSHD ClientAliveInterval to 900	78
8.51. Limit SSHD to FIPS Compliant Connections	79
8.52. Configure SSHD Unused Connection Timeout to 900	81
8.53. Configure Sudo To Log Events	82
8.54. Configure Sudoers Timestamp Type	82
8.55. Disable Trivial File Transfer Protocol Service	83
8.56. Enable Time Synchronization Daemon	84
8.57. Disable TouchID Prompt during Setup Assistant	85
8.58. Disable Login to Other User's Active and Locked Sessions	86
8.59. Disable Unix-to-Unix Copy Protocol Service	87
8.60. Disable Apple Intelligence Writing Tools	88
8.61. Disable AppleID and Internet Account Modifications	88
9. System Settings	90
9.1. Prevent Apple Watch from Terminating a Session Lock	90
9.2. Disable Unattended or Automatic Logon to the System	91
9.3. Enforce Auto Logout After 86400 Seconds of Inactivity	91
9.4. Disable Bluetooth When no Approved Device is Connected	92
9.5. Disable Bluetooth Sharing	93
9.6. Disable Content Caching Service	94
9.7. Disable Sending Diagnostic and Usage Data to Apple	95
9.8. Disable External Intelligence Integrations	96
9.9. Disable External Intelligence Integration Sign In	97
9.10. Enforce FileVault	97
9.11. Disable Find My Service	98
9.12. Enable macOS Application Firewall	100
9.13. Enable Firewall Stealth Mode	100
9.14. Apply Gatekeeper Settings to Block Applications from Unidentified Developers	101

9.15. Configure Gatekeeper to Disallow End User Override	103
9.16. Disable Guest Access to Shared SMB Folders.....	103
9.17. Disable the Guest Account	104
9.18. Disable Hot Corners.....	105
9.19. Disable Sending Audio Recordings and Transcripts to Apple	106
9.20. Disable Improve Search Information to Apple.....	107
9.21. Disable Improve Siri and Dictation Information to Apple.....	107
9.22. Disable the Internet Accounts System Preference Pane.....	108
9.23. Disable Internet Sharing	109
9.24. Disable Location Services.....	110
9.25. Configure Login Window to Prompt for Username and Password	111
9.26. Disable Media Sharing	111
9.27. Disable Password Hints	113
9.28. Disable Personalized Advertising.....	113
9.29. Disable Remote Apple Events	114
9.30. Disable Screen Sharing and Apple Remote Desktop	115
9.31. Enforce Session Lock After Screen Saver is Started	116
9.32. Enforce Screen Saver Password	117
9.33. Enforce Screen Saver Timeout	117
9.34. Disable Siri.....	118
9.35. Disable Server Message Block Sharing	119
9.36. Ensure Software Update is Updated and Current	120
9.37. Enable SSH Server for Remote Access Sessions	120
9.38. Require Administrator Password to Modify System-Wide Preferences	121
9.39. Configure macOS to Use an Authorized Time Server	123
9.40. Enforce macOS Time Synchronization	124
9.41. Disable TouchID for Unlocking the Device.....	125

Chapter 1. Foreword

The macOS Security Compliance Project is an open source effort to provide a programmatic approach to generating security guidance. The configuration settings in this document were derived from National Institute of Standards and Technology (NIST) Special Publication (SP) 800-53, *Security and Privacy Controls for Information Systems and Organizations*, Revision 5.

This project can be used as a resource to easily create customized security baselines of technical security controls by leveraging a library of atomic actions which are mapped to the compliance requirements defined in NIST SP 800-53 (Rev. 5). It can also be used to develop customized guidance to meet the particular cybersecurity needs of any organization.

The objective of this effort was to simplify and radically accelerate the process of producing up-to-date macOS security guidance that is also accessible to any organization and tailorable to meet each organization's specific security needs.

Any and all risk based decisions to tailor the content produced by this project in order to meet the needs of a specific organization shall be approved by the responsible Information System Owner (ISO) and Authorizing Official (AO) and formally documented in their System Security Plan (SSP). While the project attempts to provide settings to meet compliance requirements, it is recommended that each rule be reviewed by your organization's Information System Security Officer (ISSO) prior to implementation.

Chapter 2. Scope

Custom NIST 800-171 baseline for diwai.org Mac mini M4 Pro domain controller. Excludes: smartcard authentication, password policy (deferred to FreeIPA), MDM requirement, firmware password (handled separately), and SSH disable.

Chapter 3. Authors

Based on NIST mSCP 800-171 baseline. Customized for CyberHygiene Project.

Chapter 4. Acronyms and Definitions

Table 1. Acronyms and Abbreviations

AES	Advanced Encryption Standard
ABM	Apple Business Manager
AFP	Apple Filing Protocol
ALF	Application Layer Firewall
AO	Authorizing Official
API	Application Programming Interface
ARD	Apple Remote Desktop
CA	Certificate Authority
CIS	Center for Internet Security
CMMC	Cybersecurity Maturity Model Certification
CNSSI	Committee on National Security Systems
CRL	Certificate Revocation List
DISA	Defense Information Systems Agency
DMA	Direct Memory Access
FISMA	Federal Information Security Modernization Act
FPKI	Federal Public Key Infrastructure
IR	Infrared
ISO	Information System Owner
ISSO	Information System Security Officer
MDM	Mobile Device Management
NASA	National Aeronautics and Space Administration
NFS	Network File System
NIST	National Institute of Standards and Technology
NSA	National Security Agency
OCSF	Online Certificate Status Protocol
ODV	Organization Defined Values
OS	Operating System
PF	Packet Filter
PIV	Personal Identity Verification
PIV-M	Personal Identity Verification Mandatory
PKI	Public Key Infrastructure
RBD	Risk Based Decision

SIP	System Integrity Protection
SMB	Server Message Block
SSH	Secure Shell
SSP	System Security Plan
STIG	Security Technical Implementation Guide
UAMDM	User Approved MDM
UUCP	Unix-to-Unix Copy Protocol

Table 2. Definitions

Baseline	A baseline is a predefined set of controls (also referred to as "a catalog" of settings) that address the protection needs of an organization's information systems. A baseline serves as a starting point for the creation of security benchmarks.
Benchmark	Benchmarks are a defined list of settings with values that an organization has defined.

Chapter 5. Applicable Documents

5.1. Government Documents

Table 3. National Institute of Standards and Technology (NIST)

Document Number or Descriptor	Document Title
NIST Special Publication 800-53 Rev 5	<i>NIST Special Publication 800-53 Rev 5.1.1</i>
NIST Special Publication 800-63	<i>NIST Special Publication 800-63</i>
NIST Special Publication 800-171	<i>NIST Special Publication 800-171 Rev 3</i>
NIST Special Publication 800-219	<i>NIST Special Publication 800-219 Rev 1</i>

Table 4. Defense Information Systems Agency (DISA)

Document Number or Descriptor	Document Title
STIG Ver 1, Rel 1	<i>Apple macOS 26 (Tahoe) STIG</i>

Table 5. Cybersecurity Maturity Model Certification (CMMC)

Document Number or Descriptor	Document Title
CMMC Model Overview v2.0	<i>Cybersecurity Maturity Model Certification (CMMC) Model Overview v2.0</i>

Table 6. Committee on National Security Systems (CNSS)

Document Number or Descriptor	Document Title
CNSSI No. 1253	<i>Security Categorization and Control Selection for National Security Systems</i>

5.2. Non-Government Documents

Table 7. Apple

Document Number or Descriptor	Document Title
Apple Platform Security Guide	<i>Apple Platform Security</i>
Apple Platform Deployment	<i>Apple Platform Deployment</i>
Apple Platform Certifications	<i>Apple Platform Certifications</i>
Profile-Specific Payload Keys	<i>Profile-Specific Payload Keys</i>

Table 8. Center for Internet Security

Document Number or Descriptor	Document Title
Apple macOS 26.0	<i>CIS Apple macOS 26.0 Benchmark version 1.0.0</i>

Chapter 6. iCloud

This section contains the configuration and enforcement of iCloud and the Apple ID service settings.



The check/fix commands outlined in this section *MUST* be run by a user with with elevated privileges.

6.1. Disable iCloud Address Book

The macOS built-in Contacts.app connection to Apple’s iCloud service *MUST* be disabled.

Apple’s iCloud service does not provide an organization with enough control over the storage and access of data, and, therefore, automated contact synchronization *MUST* be controlled by an organization approved service.

To check the state of the system, run the following command(s):

```
/usr/bin/osascript -l JavaScript << EOS
$.NSUserDefaults.alloc.initWithSuiteName('com.apple.applicationaccess')\
.objectForKey('allowCloudAddressBook').js
EOS
```

If the result is not **false**, this is a finding.

Remediation Description

Perform the following to configure the system to meet the requirements:

Create a configuration profile containing the following keys in the (com.apple.applicationaccess) payload type:

```
<key>allowCloudAddressBook</key>
<false/>
```

ID	icloud_addressbook_disable	
References	800-53r5	• AC-20, AC-20(1) • CM-7, CM-7(1) • SC-7(10)
	CCE	• CCE-95140-0

6.2. Disable the System Setting for Apple ID

The system setting for Apple ID *MUST* be disabled.

Disabling the system setting prevents login to Apple ID and iCloud.

To check the state of the system, run the following command(s):

```
/usr/bin/profiles show -output stdout-xml | /usr/bin/xmllint --xpath
'//key[text()="DisabledSystemSettings"]/following-sibling::*[1]' - | /usr/bin/grep -c
"com.apple.systempreferences.AppleIDSettings"
```

If the result is not 1, this is a finding.

Remediation Description

Perform the following to configure the system to meet the requirements:

Create a configuration profile containing the following keys in the (com.apple.systempreferences) payload type:

```
<key>DisabledSystemSettings</key>
<array>
  <string>com.apple.systempreferences.AppleIDSettings</string>
</array>
```

ID	icloud_appleid_system_settings_disable	
References	800-53r5	- AC-20, AC-20(1) - CM-7, CM-7(1)
	CCE	CCE-95141-8

6.3. Disable iCloud Bookmarks

The macOS built-in Safari.app bookmark synchronization via the iCloud service *MUST* be disabled.

Apple's iCloud service does not provide an organization with enough control over the storage and access of data and, therefore, automated bookmark synchronization *MUST* be controlled by an organization approved service.

To check the state of the system, run the following command(s):

```
/usr/bin/osascript -l JavaScript << EOS
$.NSUserDefaults.alloc.initWithSuiteName('com.apple.applicationaccess')\
.objectForKey('allowCloudBookmarks').js
```

If the result is not **false**, this is a finding.

Remediation Description

Perform the following to configure the system to meet the requirements:

Create a configuration profile containing the following keys in the (com.apple.applicationaccess) payload type:

```
<key>allowCloudBookmarks</key>
<false/>
```

ID	icloud_bookmarks_disable	
References	800-53r5	• AC-20, AC-20(1) • CM-7, CM-7(1) • SC-7(10)
	CCE	• CCE-95142-6

6.4. Disable the iCloud Calendar Services

The macOS built-in Calendar.app connection to Apple's iCloud service *MUST* be disabled.

Apple's iCloud service does not provide an organization with enough control over the storage and access of data and, therefore, automated calendar synchronization *MUST* be controlled by an organization approved service.

To check the state of the system, run the following command(s):

```
/usr/bin/osascript -l JavaScript << EOS
$.NSUserDefaults.alloc.initWithSuiteName('com.apple.applicationaccess')\
.objectForKey('allowCloudCalendar').js
EOS
```

If the result is not **false**, this is a finding.

Remediation Description

Perform the following to configure the system to meet the requirements:

Create a configuration profile containing the following keys in the (com.apple.applicationaccess) payload type:

```
<key>allowCloudCalendar</key>
<false/>
```

ID	icloud_calendar_disable	
References	800-53r5	• AC-20, AC-20(1) • CM-7, CM-7(1) • SC-7(10)
	CCE	• CCE-95143-4

6.5. Disable iCloud Document Sync

The macOS built-in iCloud document synchronization service *MUST* be disabled to prevent organizational data from being synchronized to personal or non-approved storage.

Apple's iCloud service does not provide an organization with enough control over the storage and access of data and, therefore, automated document synchronization *MUST* be controlled by an organization approved service.

To check the state of the system, run the following command(s):

```
/usr/bin/osascript -l JavaScript << EOS
$.NSUserDefaults.alloc.initWithSuiteName('com.apple.applicationaccess')\
.objectForKey('allowCloudDocumentSync').js
EOS
```

If the result is not **false**, this is a finding.

Remediation Description

Perform the following to configure the system to meet the requirements:

Create a configuration profile containing the following keys in the (com.apple.applicationaccess) payload type:

```
<key>allowCloudDocumentSync</key>
<false/>
```

ID	icloud_drive_disable
----	----------------------

References	800-53r5	• AC-20, AC-20(1) • CM-7, CM-7(1) • SC-7(10)
	CCE	• CCE-95144-2

6.6. Disable the iCloud Freeform Services

The macOS built-in Freeform.app connection to Apple’s iCloud service *MUST* be disabled.

Apple’s iCloud service does not provide an organization with enough control over the storage and access of data and, therefore, automated calendar synchronization *MUST* be controlled by an organization approved service.

To check the state of the system, run the following command(s):

```
/usr/bin/osascript -l JavaScript << EOS
$.NSUserDefaults.alloc.initWithSuiteName('com.apple.applicationaccess')\
.objectForKey('allowCloudFreeform').js
EOS
```

If the result is not **false**, this is a finding.

Remediation Description

Perform the following to configure the system to meet the requirements:

Create a configuration profile containing the following keys in the (com.apple.applicationaccess) payload type:

```
<key>allowCloudFreeform</key>
<false/>
```

ID	icloud_freeform_disable	
References	800-53r5	• AC-20, AC-20(1) • CM-7, CM-7(1) • SC-7(10)
	CCE	• CCE-95145-9

6.7. Disable iCloud Game Center

This works only with supervised devices (MDM) and allows to disable Apple Game Center. The

rationale is Game Center is using Apple ID and will shared data on AppleID based services, therefore, Game Center *MUST* be disabled. This setting also prohibits functionality of adding friends to Game Center.

To check the state of the system, run the following command(s):

```
/usr/bin/osascript -l JavaScript << EOS
$.NSUserDefaults.alloc.initWithSuiteName('com.apple.applicationaccess')\
.objectForKey('allowGameCenter').js
EOS
```

If the result is not **false**, this is a finding.

Remediation Description

Perform the following to configure the system to meet the requirements:

Create a configuration profile containing the following keys in the (com.apple.applicationaccess) payload type:

```
<key>allowGameCenter</key>
<false/>
```

ID	icloud_game_center_disable	
References	800-53r5	• AC-20, AC-20(1) • CM-7, CM-7(1) • SC-7(10)
	CCE	• CCE-95146-7

6.8. Disable iCloud Keychain Sync

The macOS system's ability to automatically synchronize a user's passwords to their iCloud account *MUST* be disabled.

Apple's iCloud service does not provide an organization with enough control over the storage and access of data and, therefore, password management and synchronization *MUST* be controlled by an organization approved service.

To check the state of the system, run the following command(s):

```
/usr/bin/osascript -l JavaScript << EOS
$.NSUserDefaults.alloc.initWithSuiteName('com.apple.applicationaccess')\
.objectForKey('allowCloudKeychainSync').js
```

If the result is not **false**, this is a finding.

Remediation Description

Perform the following to configure the system to meet the requirements:

Create a configuration profile containing the following keys in the (com.apple.applicationaccess) payload type:

```
<key>allowCloudKeychainSync</key>
<false/>
```

ID	icloud_keychain_disable	
References	800-53r5	• AC-20, AC-20(1) • CM-7, CM-7(1) • SC-7(10)
	CCE	• CCE-95147-5

6.9. Disable iCloud Mail

The macOS built-in Mail.app connection to Apple's iCloud service *MUST* be disabled.

Apple's iCloud service does not provide an organization with enough control over the storage and access of data and, therefore, automated mail synchronization *MUST* be controlled by an organization approved service.

To check the state of the system, run the following command(s):

```
/usr/bin/osascript -l JavaScript << EOS
$.NSUserDefaults.alloc.initWithSuiteName('com.apple.applicationaccess')\
.objectForKey('allowCloudMail').js
EOS
```

If the result is not **false**, this is a finding.

Remediation Description

Perform the following to configure the system to meet the requirements:

Create a configuration profile containing the following keys in the (com.apple.applicationaccess) payload type:

```
<key>allowCloudMail</key>
<false/>
```

ID	icloud_mail_disable	
References	800-53r5	• AC-20, AC-20(1) • CM-7, CM-7(1) • SC-7(10)
	CCE	• CCE-95148-3

6.10. Disable iCloud Notes

The macOS built-in Notes.app connection to Apple's iCloud service *MUST* be disabled.

Apple's iCloud service does not provide an organization with enough control over the storage and access of data and, therefore, automated Notes synchronization *MUST* be controlled by an organization approved service.

To check the state of the system, run the following command(s):

```
/usr/bin/osascript -l JavaScript << EOS
$.NSUserDefaults.alloc.initWithSuiteName('com.apple.applicationaccess')\
.objectForKey('allowCloudNotes').js
EOS
```

If the result is not **false**, this is a finding.

Remediation Description

Perform the following to configure the system to meet the requirements:

Create a configuration profile containing the following keys in the (com.apple.applicationaccess) payload type:

```
<key>allowCloudNotes</key>
<false/>
```

ID	icloud_notes_disable
----	----------------------

References	800-53r5	• AC-20, AC-20(1) • CM-7, CM-7(1) • SC-7(10)
	CCE	• CCE-95149-1

6.11. Disable iCloud Photo Library

The macOS built-in Photos.app connection to Apple’s iCloud service *MUST* be disabled.

Apple’s iCloud service does not provide an organization with enough control over the storage and access of data and, therefore, automated photo synchronization *MUST* be controlled by an organization approved service.

To check the state of the system, run the following command(s):

```
/usr/bin/osascript -l JavaScript << EOS
$.NSUserDefaults.alloc.initWithSuiteName('com.apple.applicationaccess')\
.objectForKey('allowCloudPhotoLibrary').js
EOS
```

If the result is not **false**, this is a finding.

Remediation Description

Perform the following to configure the system to meet the requirements:

Create a configuration profile containing the following keys in the (com.apple.applicationaccess) payload type:

```
<key>allowCloudPhotoLibrary</key>
<false/>
```

ID	icloud_photos_disable	
References	800-53r5	• AC-20, AC-20(1) • CM-7, CM-7(1) • SC-7(10)
	CCE	• CCE-95150-9

6.12. Disable iCloud Private Relay

Enterprise networks may be required to audit all network traffic by policy, therefore, iCloud Private

Relay *MUST* be disabled.

Network administrators can also prevent the use of this feature by blocking DNS resolution of mask.icloud.com and mask-h2.icloud.com.

To check the state of the system, run the following command(s):

```
/usr/bin/osascript -l JavaScript << EOS
$.NSUserDefaults.alloc.initWithSuiteName('com.apple.applicationaccess')\
.objectForKey('allowCloudPrivateRelay').js
EOS
```

If the result is not **false**, this is a finding.

Remediation Description

Perform the following to configure the system to meet the requirements:

Create a configuration profile containing the following keys in the (com.apple.applicationaccess) payload type:

```
<key>allowCloudPrivateRelay</key>
<false/>
```

ID	icloud_private_relay_disable	
References	800-53r5	• AC-20, AC-20(1) • CM-7, CM-7(1) • SC-7(10)
	CCE	• CCE-95151-7

6.13. Disable iCloud Reminders

The macOS built-in Reminders.app connection to Apple's iCloud service *MUST* be disabled.

Apple's iCloud service does not provide an organization with enough control over the storage and access of data and, therefore, automated reminders synchronization *MUST* be controlled by an organization approved service.

To check the state of the system, run the following command(s):

```
/usr/bin/osascript -l JavaScript << EOS
$.NSUserDefaults.alloc.initWithSuiteName('com.apple.applicationaccess')\
.objectForKey('allowCloudReminders').js
```

If the result is not **false**, this is a finding.

Remediation Description

Perform the following to configure the system to meet the requirements:

Create a configuration profile containing the following keys in the (com.apple.applicationaccess) payload type:

```
<key>allowCloudReminders</key>
<false/>
```

ID	icloud_reminders_disable	
References	800-53r5	• AC-20, AC-20(1) • CM-7, CM-7(1) • SC-7(10)
	CCE	• CCE-95152-5

6.14. Disable iCloud Desktop and Document Folder Sync

The macOS system's ability to automatically synchronize a user's desktop and documents folder to their iCloud Drive *MUST* be disabled.

Apple's iCloud service does not provide an organization with enough control over the storage and access of data and, therefore, automated file synchronization *MUST* be controlled by an organization approved service.

To check the state of the system, run the following command(s):

```
/usr/bin/osascript -l JavaScript << EOS
$.NSUserDefaults.alloc.initWithSuiteName('com.apple.applicationaccess')\
.objectForKey('allowCloudDesktopAndDocuments').js
EOS
```

If the result is not **false**, this is a finding.

Remediation Description

Perform the following to configure the system to meet the requirements:

Create a configuration profile containing the following keys in the (com.apple.applicationaccess) payload type:

```
<key>allowCloudDesktopAndDocuments</key>
<false/>
```

ID	icloud_sync_disable	
References	800-53r5	• AC-20, AC-20(1) • CM-7, CM-7(1) • SC-7(10)
	CCE	• CCE-95153-3

Chapter 7. Auditing

This section contains the configuration and enforcement of the OpenBSM settings.



The BSM Audit subsystem has been marked as deprecated by Apple.



The check/fix commands outlined in this section *MUST* be run with elevated privileges.

7.1. Configure Audit Log Files to Not Contain Access Control Lists

The audit log files *MUST* not contain access control lists (ACLs).

This rule ensures that audit information and audit files are configured to be readable and writable only by system administrators, thereby preventing unauthorized access, modification, and deletion of files.

To check the state of the system, run the following command(s):

```
/bin/ls -le $(/usr/bin/grep '^dir' /etc/security/audit_control | /usr/bin/awk -F: '{print $2}') | /usr/bin/awk '{print $1}' | /usr/bin/grep -c ":"
```

If the result is not 0, this is a finding.

Remediation Description

Perform the following to configure the system to meet the requirements:

```
/bin/chmod -RN /var/audit
```

ID	audit_acls_files_configure	
References	800-53r5	• AU-9
	CCE	• CCE-95101-2

7.2. Configure Audit Log Folder to Not Contain Access Control Lists

The audit log folder *MUST* not contain access control lists (ACLs).

Audit logs contain sensitive data about the system and users. This rule ensures that the audit

service is configured to create log folders that are readable and writable only by system administrators in order to prevent normal users from reading audit logs.

To check the state of the system, run the following command(s):

```
/bin/ls -lde /var/audit | /usr/bin/awk '{print $1}' | /usr/bin/grep -c ":"
```

If the result is not **0**, this is a finding.

Remediation Description

Perform the following to configure the system to meet the requirements:

```
/bin/chmod -N /var/audit
```

ID	audit_acls_folders_configure	
References	800-53r5	• AU-9
	CCE	• CCE-95102-0

7.3. Enable Security Auditing

The information system *MUST* be configured to generate audit records.

Audit records establish what types of events have occurred, when they occurred, and which users were involved. These records aid an organization in their efforts to establish, correlate, and investigate the events leading up to an outage or attack.

The content required to be captured in an audit record varies based on the impact level of an organization's system. Content that may be necessary to satisfy this requirement includes, for example, time stamps, source addresses, destination addresses, user identifiers, event descriptions, success/fail indications, filenames involved, and access or flow control rules invoked.

The information system initiates session audits at system start-up.



Security auditing is NOT enabled by default on macOS Tahoe.

To check the state of the system, run the following command(s):

```
LAUNCHD_RUNNING=$( /bin/launchctl print system | /usr/bin/grep -c -E
'\tcom.apple.auditd' )
AUDITD_RUNNING=$( /usr/sbin/audit -c | /usr/bin/grep -c "AUC_AUDITING" )
if [[ $LAUNCHD_RUNNING == 1 ]] && [[ -e /etc/security/audit_control ]] && [[
$AUDITD_RUNNING == 1 ]]; then
    echo "pass"
```

```
else
  echo "fail"
fi
```

If the result is not **pass**, this is a finding.

Remediation Description

Perform the following to configure the system to meet the requirements:

```
if [[ ! -e /etc/security/audit_control ]] && [[ -e
/etc/security/audit_control.example ]];then
  /bin/cp /etc/security/audit_control.example /etc/security/audit_control
fi

/bin/launchctl enable system/com.apple.auditd
/bin/launchctl bootstrap system
/System/Library/LaunchDaemons/com.apple.auditd.plist
/usr/sbin/audit -i
```

ID	audit_auditd_enabled	
References	800-53r5	• AU-12, AU-12(1), AU-12(3) • AU-14(1) • AU-3, AU-3(1) • AU-8 • CM-5(1) • MA-4(1)
	CCE	• CCE-95104-6

7.4. Configure System to Shut Down Upon Audit Failure

The audit service *MUST* be configured to shut down the computer if it is unable to audit system events.

Once audit failure occurs, user and system activity are no longer recorded, and malicious activity could go undetected. Audit processing failures can occur due to software/hardware errors, failures in the audit capturing mechanisms, and audit storage capacity being reached or exceeded.

To check the state of the system, run the following command(s):

```
/usr/bin/awk -F':' ' /^policy/ {print $NF}' /etc/security/audit_control | /usr/bin/tr
```

```
',' '\n' | /usr/bin/grep -Ec 'ahlt'
```

If the result is not **1**, this is a finding.

Remediation Description

Perform the following to configure the system to meet the requirements:

```
/usr/bin/sed -i.bak 's/^policy.*/policy: ahlT,argv/' /etc/security/audit_control;  
/usr/sbin/audit -s
```

ID	audit_failure_halt	
References	800-53r5	• AU-5
	CCE	• CCE-95111-1

7.5. Configure Audit Log Files Group to Wheel

Audit log files *MUST* have the group set to wheel.

The audit service *MUST* be configured to create log files with the correct group ownership to prevent normal users from reading audit logs.

Audit logs contain sensitive data about the system and users. If log files are set to be readable and writable only by system administrators, the risk is mitigated.

To check the state of the system, run the following command(s):

```
/bin/ls -n $(/usr/bin/grep '^dir' /etc/security/audit_control | /usr/bin/awk -F:  
'{print $2}') | /usr/bin/awk '{s+=$4} END {print s}'
```

If the result is not **0**, this is a finding.

Remediation Description

Perform the following to configure the system to meet the requirements:

```
/usr/bin/chgrp -R wheel /var/audit/*
```

ID	audit_files_group_configure
-----------	-----------------------------

References	800-53r5	• AU-9
	CCE	• CCE-95112-9

7.6. Configure Audit Log Files to Mode 440 or Less Permissive

The audit service *MUST* be configured to create log files that are readable only by the root user and group wheel. To achieve this, audit log files *MUST* be configured to mode 440 or less permissive; thereby preventing normal users from reading, modifying or deleting audit logs.

To check the state of the system, run the following command(s):

```
/bin/ls -l $(/usr/bin/grep '^dir' /etc/security/audit_control | /usr/bin/awk -F: '{print $2}') | /usr/bin/awk '!/-r--r-----|current|total/{print $1}' | /usr/bin/wc -l | /usr/bin/tr -d ' '
```

If the result is not **0**, this is a finding.

Remediation Description

Perform the following to configure the system to meet the requirements:

```
/bin/chmod 440 /var/audit/*
```

ID	audit_files_mode_configure	
References	800-53r5	• AU-9
	CCE	• CCE-95113-7

7.7. Configure Audit Log Files to be Owned by Root

Audit log files *MUST* be owned by root.

The audit service *MUST* be configured to create log files with the correct ownership to prevent normal users from reading audit logs.

Audit logs contain sensitive data about the system and users. If log files are set to only be readable and writable by system administrators, the risk is mitigated.

To check the state of the system, run the following command(s):

```
/bin/ls -n $(/usr/bin/grep '^dir' /etc/security/audit_control | /usr/bin/awk -F:
```

```
'{print $2}')) | /usr/bin/awk '{s+=$3} END {print s}'
```

If the result is not **0**, this is a finding.

Remediation Description

Perform the following to configure the system to meet the requirements:

```
/usr/sbin/chown -R root /var/audit/*
```

ID	audit_files_owner_configure	
References	800-53r5	• AU-9
	CCE	• CCE-95114-5

7.8. Configure System to Audit All Authorization and Authentication Events

The auditing system *MUST* be configured to flag authorization and authentication (aa) events.

Authentication events contain information about the identity of a user, server, or client. Authorization events contain information about permissions, rights, and rules. If audit records do not include aa events, it is difficult to identify incidents and to correlate incidents to subsequent events.

Audit records can be generated from various components within the information system (e.g., via a module or policy filter).

To check the state of the system, run the following command(s):

```
/usr/bin/awk -F':' '/^flags/ { print $NF }' /etc/security/audit_control | /usr/bin/tr  
, '\n' | /usr/bin/grep -Ec 'aa'
```

If the result is not **1**, this is a finding.

Remediation Description

Perform the following to configure the system to meet the requirements:

```
/usr/bin/grep -qE "^[^]aa" /etc/security/audit_control || /usr/bin/sed -  
i.bak '/^flags/ s$/ ,aa/' /etc/security/audit_control; /usr/sbin/audit -s
```

ID	audit_flags_aa_configure	
References	800-53r5	• AC-2(12) • AU-12 • AU-2 • CM-5(1) • MA-4(1)
	CCE	• CCE-95115-2

7.9. Configure System to Audit All Administrative Action Events

The auditing system *MUST* be configured to flag administrative action (ad) events.

Administrative action events include changes made to the system (e.g. modifying authentication policies). If audit records do not include ad events, it is difficult to identify incidents and to correlate incidents to subsequent events.

Audit records can be generated from various components within the information system (e.g., via a module or policy filter).

The information system audits the execution of privileged functions.



We recommend changing the line "43127:AUE_MAC_SYSCALL:mac_syscall(2):ad" to "43127:AUE_MAC_SYSCALL:mac_syscall(2):zz" in the file /etc/security/audit_event. This will prevent sandbox violations from being audited by the ad flag.

To check the state of the system, run the following command(s):

```
/usr/bin/awk -F':' '/^flags/ { print $NF }' /etc/security/audit_control | /usr/bin/tr
',' '\n' | /usr/bin/grep -Ec 'ad'
```

If the result is not 1, this is a finding.

Remediation Description

Perform the following to configure the system to meet the requirements:

```
/usr/bin/grep -qE "^flags.*[^-]ad" /etc/security/audit_control || /usr/bin/sed -
i.bak '/^flags/ s/$/,ad/' /etc/security/audit_control; /usr/sbin/audit -s
```

ID	audit_flags_ad_configure
-----------	--------------------------

References	800-53r5	• AC-2(12), AC-2(4) • AC-6(9) • AU-12 • AU-2 • CM-5(1) • MA-4(1)
	CCE	• CCE-95116-0

7.10. Configure System to Audit All Failed Program Execution on the System

The audit system *MUST* be configured to record enforcement actions of access restrictions, including failed program execute (-ex) attempts.

Enforcement actions are the methods or mechanisms used to prevent unauthorized access and/or changes to configuration settings. One common and effective enforcement action method is using program execution restrictions (e.g., denying users access to execute certain processes).

This configuration ensures that audit lists include events in which program execution has failed. Without auditing the enforcement of program execution, it is difficult to identify attempted attacks, as there is no audit trail available for forensic investigation.

To check the state of the system, run the following command(s):

```
/usr/bin/awk -F':' '/^flags/ { print $NF }' /etc/security/audit_control | /usr/bin/tr
',' '\n' | /usr/bin/grep -Ec '\-ex'
```

If the result is not 1, this is a finding.

Remediation Description

Perform the following to configure the system to meet the requirements:

```
/usr/bin/grep -qE "^flags.*-ex" /etc/security/audit_control || /usr/bin/sed -i.bak
'/^flags/ s/$/, -ex/' /etc/security/audit_control; /usr/sbin/audit -s
```

ID	audit_flags_ex_configure
----	--------------------------

References	800-53r5	• AC-2(12) • AU-12 • AU-2 • CM-5(1)
	CCE	• CCE-95117-8

7.11. Configure System to Audit All Failed Change of Object Attributes

The audit system *MUST* be configured to record enforcement actions of failed attempts to modify file attributes (-fm).

Enforcement actions are the methods or mechanisms used to prevent unauthorized changes to configuration settings. One common and effective enforcement action method is using access restrictions (i.e., denying modifications to a file by applying file permissions).

This configuration ensures that audit lists include events in which enforcement actions prevent attempts to modify a file.

Without auditing the enforcement of access restrictions, it is difficult to identify attempted attacks, as there is no audit trail available for forensic investigation.

To check the state of the system, run the following command(s):

```
/usr/bin/awk -F':' ' /^flags/ { print $NF }' /etc/security/audit_control | /usr/bin/tr
',' '\n' | /usr/bin/grep -Ec '\-fm'
```

If the result is not 1, this is a finding.

Remediation Description

Perform the following to configure the system to meet the requirements:

```
/usr/bin/grep -qE "^flags.*-fm" /etc/security/audit_control || /usr/bin/sed -i.bak
'/^flags/ s/$/, -fm/' /etc/security/audit_control;/usr/sbin/audit -s
```

ID	audit_flags_fm_failed_configure
----	---------------------------------

References	800-53r5	• AC-2(12) • AU-12 • AU-2 • AU-9 • CM-5(1) • MA-4(1)
	CCE	• CCE-95120-2

7.12. Configure System to Audit All Failed Read Actions on the System

The audit system *MUST* be configured to record enforcement actions of access restrictions, including failed file read (-fr) attempts.

Enforcement actions are the methods or mechanisms used to prevent unauthorized access and/or changes to configuration settings. One common and effective enforcement action method is using access restrictions (e.g., denying access to a file by applying file permissions).

This configuration ensures that audit lists include events in which enforcement actions prevent attempts to read a file.

Without auditing the enforcement of access restrictions, it is difficult to identify attempted attacks, as there is no audit trail available for forensic investigation.

To check the state of the system, run the following command(s):

```
/usr/bin/awk -F':' '/^flags/ { print $NF }' /etc/security/audit_control | /usr/bin/tr
',' '\n' | /usr/bin/grep -Ec '\-fr'
```

If the result is not 1, this is a finding.

Remediation Description

Perform the following to configure the system to meet the requirements:

```
/usr/bin/grep -qE "^flags.*-fr" /etc/security/audit_control || /usr/bin/sed -i.bak
'^flags/ s/$/, -fr/' /etc/security/audit_control;/usr/sbin/audit -s
```

ID	audit_flags_fr_configure
----	--------------------------

References	800-53r5	• AC-2(12) • AU-12 • AU-2 • AU-9 • CM-5(1) • MA-4(1)
	CCE	• CCE-95121-0

7.13. Configure System to Audit All Failed Write Actions on the System

The audit system *MUST* be configured to record enforcement actions of access restrictions, including failed file write (-fw) attempts.

Enforcement actions are the methods or mechanisms used to prevent unauthorized access and/or changes to configuration settings. One common and effective enforcement action method is using access restrictions (e.g., denying users access to edit a file by applying file permissions).

This configuration ensures that audit lists include events in which enforcement actions prevent attempts to change a file.

Without auditing the enforcement of access restrictions, it is difficult to identify attempted attacks, as there is no audit trail available for forensic investigation.

To check the state of the system, run the following command(s):

```
/usr/bin/awk -F':' '/^flags/ { print $NF }' /etc/security/audit_control | /usr/bin/tr
',' '\n' | /usr/bin/grep -Ec '\-fw'
```

If the result is not 1, this is a finding.

Remediation Description

Perform the following to configure the system to meet the requirements:

```
/usr/bin/grep -qE "^flags.*-fw" /etc/security/audit_control || /usr/bin/sed -i.bak
'^flags/ s/$/, -fw/' /etc/security/audit_control;/usr/sbin/audit -s
```

ID	audit_flags_fw_configure
----	--------------------------

References	800-53r5	• AC-2(12) • AU-12 • AU-2 • AU-9 • CM-5(1) • MA-4(1)
	CCE	• CCE-95122-8

7.14. Configure System to Audit All Log In and Log Out Events

The audit system *MUST* be configured to record all attempts to log in and out of the system (lo).

Frequently, an attacker that successfully gains access to a system has only gained access to an account with limited privileges, such as a guest account or a service account. The attacker must attempt to change to another user account with normal or elevated privileges in order to proceed. Auditing both successful and unsuccessful attempts to switch to another user account (by way of monitoring login and logout events) mitigates this risk.

The information system monitors login and logout events.

To check the state of the system, run the following command(s):

```
/usr/bin/awk -F':' ' /^flags/ { print $NF }' /etc/security/audit_control | /usr/bin/tr
',' '\n' | /usr/bin/grep -Ec '^lo'
```

If the result is not 1, this is a finding.

Remediation Description

Perform the following to configure the system to meet the requirements:

```
/usr/bin/grep -qE "^flags.*[^-]lo" /etc/security/audit_control || /usr/bin/sed -
i.bak '/^flags/ s/$/,lo/' /etc/security/audit_control; /usr/sbin/audit -s
```

ID	audit_flags_lo_configure
----	--------------------------

References	800-53r5	• AC-17(1) • AC-2(12) • AU-12 • AU-2 • MA-4(1)
	CCE	• CCE-95123-6

7.15. Configure Audit Log Folders Group to Wheel

Audit log files *MUST* have the group set to wheel.

The audit service *MUST* be configured to create log files with the correct group ownership to prevent normal users from reading audit logs.

Audit logs contain sensitive data about the system and users. If log files are set to be readable and writable only by system administrators, the risk is mitigated.

To check the state of the system, run the following command(s):

```
/bin/ls -dn $(/usr/bin/grep '^dir' /etc/security/audit_control | /usr/bin/awk -F: '{print $2}') | /usr/bin/awk '{print $4}'
```

If the result is not **0**, this is a finding.

Remediation Description

Perform the following to configure the system to meet the requirements:

```
/usr/bin/chgrp wheel /var/audit
```

ID	audit_folder_group_configure	
References	800-53r5	• AU-9
	CCE	• CCE-95124-4

7.16. Configure Audit Log Folders to be Owned by Root

Audit log folders *MUST* be owned by root.

The audit service *MUST* be configured to create log folders with the correct ownership to prevent normal users from reading audit logs.

Audit logs contain sensitive data about the system and users. If log folders are set to only be readable and writable by system administrators, the risk is mitigated.

To check the state of the system, run the following command(s):

```
/bin/ls -dn $(/usr/bin/grep '^dir' /etc/security/audit_control | /usr/bin/awk -F: '{print $2}') | /usr/bin/awk '{print $3}'
```

If the result is not **0**, this is a finding.

Remediation Description
Perform the following to configure the system to meet the requirements:

```
/usr/sbin/chown root /var/audit
```

ID	audit_folder_owner_configure	
References	800-53r5	• AU-9
	CCE	• CCE-95125-1

7.17. Configure Audit Log Folders to Mode 700 or Less Permissive

The audit log folder *MUST* be configured to mode 700 or less permissive so that only the root user is able to read, write, and execute changes to folders.

Because audit logs contain sensitive data about the system and users, the audit service *MUST* be configured to mode 700 or less permissive; thereby preventing normal users from reading, modifying or deleting audit logs.

To check the state of the system, run the following command(s):

```
/usr/bin/stat -f %A $(/usr/bin/grep '^dir' /etc/security/audit_control | /usr/bin/awk -F: '{print $2}')
```

If the result is not **700**, this is a finding.

Remediation Description
Perform the following to configure the system to meet the requirements:

```
/bin/chmod 700 /var/audit
```

ID	audit_folders_mode_configure	
References	800-53r5	• AU-9
	CCE	• CCE-95126-9

7.18. Configure Audit Retention to 7d

The audit service *MUST* be configured to require records be kept for a organizational defined value before deletion, unless the system uses a central audit record storage facility.

When "expire-after" is set to "7d", the audit service will not delete audit logs until the log data criteria is met.

To check the state of the system, run the following command(s):

```
/usr/bin/awk -F: '/expire-after/{print $2}' /etc/security/audit_control
```

If the result is not **7d**, this is a finding.

Remediation Description

Perform the following to configure the system to meet the requirements:

```
/usr/bin/sed -i.bak 's/^expire-after.*/expire-after:7d/'  
/etc/security/audit_control; /usr/sbin/audit -s
```

ID	audit_retention_configure	
References	800-53r5	• AU-11 • AU-4
	CCE	• CCE-95130-1

7.19. Configure Audit Failure Notification

The audit service *MUST* be configured to immediately print messages to the console or email administrator users when an auditing failure occurs.

It is critical for the appropriate personnel to be made aware immediately if a system is at risk of failing to process audit logs as required. Without a real-time alert, security personnel may be unaware of a potentially harmful failure in the auditing system's capability, and system operation

may be adversely affected.

To check the state of the system, run the following command(s):

```
/usr/bin/grep -c "logger -s -p" /etc/security/audit_warn
```

If the result is not 1, this is a finding.

Remediation Description

Perform the following to configure the system to meet the requirements:

```
/usr/bin/sed -i.bak 's/logger -p/logger -s -p/' /etc/security/audit_warn;  
/usr/sbin/audit -s
```

ID	audit_settings_failure_notify	
References	800-53r5	• AU-5, AU-5(2)
	CCE	• CCE-95131-9

Chapter 8. macOS

This section contains the configuration and enforcement of operating system settings.



The check/fix commands outlined in this section *MUST* be run by a user with elevated privileges.

8.1. Disable AirDrop

AirDrop *MUST* be disabled to prevent file transfers to or from unauthorized devices. AirDrop allows users to share and receive files from other nearby Apple devices.

To check the state of the system, run the following command(s):

```
/usr/bin/osascript -l JavaScript << EOS
$.NSUserDefaults.alloc.initWithSuiteName('com.apple.applicationaccess')\
.objectForKey('allowAirDrop').js
EOS
```

If the result is not **false**, this is a finding.

Remediation Description

Perform the following to configure the system to meet the requirements:

Create a configuration profile containing the following keys in the (com.apple.applicationaccess) payload type:

```
<key>allowAirDrop</key>
<false/>
```

ID	os_airdrop_disable	
References	800-53r5	• AC-20 • AC-3 • CM-7, CM-7(1)
	CCE	• CCE-95156-6

8.2. Disable Apple ID Setup during Setup Assistant

The prompt for Apple ID setup during Setup Assistant *MUST* be disabled.

macOS will automatically prompt new users to set up an Apple ID while they are going through

Setup Assistant if this is not disabled, misleading new users to think they need to create Apple ID accounts upon their first login.

To check the state of the system, run the following command(s):

```
/usr/bin/osascript -l JavaScript 2>/dev/null << EOS
$.NSUserDefaults.alloc.initWithSuiteName('com.apple.SetupAssistant.managed')\
.objectForKey('SkipSetupItems').containsObject("AppleID")
EOS
```

If the result is not **true**, this is a finding.

Remediation Description

Perform the following to configure the system to meet the requirements:

Create a configuration profile containing the following keys in the (com.apple.SetupAssistant.managed) payload type:

```
<key>SkipSetupItems</key>
<array>
  <string>AppleID</string>
</array>
```

ID	os_appleid_prompt_disable	
References	800-53r5	• AC-20
	CCE	• CCE-95159-0

8.3. Enable Authenticated Root

Authenticated Root *MUST* be enabled.

When Authenticated Root is enabled the macOS is booted from a signed volume that is cryptographically protected to prevent tampering with the system volume.



Authenticated Root is enabled by default on macOS systems.



If more than one partition with macOS is detected, the csrutil command will hang awaiting input.

To check the state of the system, run the following command(s):

```
/usr/libexec/mdmclient QuerySecurityInfo 2>/dev/null | /usr/bin/grep -c
```

```
"AuthenticatedRootVolumeEnabled = 1;"
```

If the result is not **1**, this is a finding.

Remediation Description

Perform the following to configure the system to meet the requirements:

```
/usr/bin/csrutil authenticated-root enable
```



To re-enable "Authenticated Root", boot the affected system into "Recovery" mode, launch "Terminal" from the "Utilities" menu, and run the command.

ID	os_authenticated_root_enable	
References	800-53r5	• AC-3 • CM-5 • MA-4(1) • SC-34 • SI-7, SI-7(6)
	CCE	• CCE-95164-0

8.4. Disable Bonjour Multicast

Bonjour multicast advertising *MUST* be disabled to prevent the system from broadcasting its presence and available services over network interfaces.

To check the state of the system, run the following command(s):

```
/usr/bin/osascript -l JavaScript << EOS
$.NSUserDefaults.alloc.initWithSuiteName('com.apple.mDNSResponder')\
.objectForKey('NoMulticastAdvertisements').js
EOS
```

If the result is not **true**, this is a finding.

Remediation Description

Perform the following to configure the system to meet the requirements:

Create a configuration profile containing the following keys in the (com.apple.mDNSResponder) payload type:

```
<key>NoMulticastAdvertisements</key>
<true/>
```

ID	os_bonjour_disable	
References	800-53r5	• CM-7, CM-7(1)
	CCE	• CCE-95169-9

8.5. Disable Burn Support

Burn support *MUST* be disabled.



Some organizations rely on the use of removable media for storing and sharing data. Information System Security Officers (ISSOs) may make the risk-based decision not to disable external hard drives to avoid losing this functionality, but they are advised to first fully weigh the potential risks posed to their organization.

To check the state of the system, run the following command(s):

```
/usr/bin/profiles -P -o stdout | /usr/bin/grep -Ec '(BurnSupport = off;|ProhibitBurn = 1;)'
```

If the result is not 2, this is a finding.

Remediation Description

Perform the following to configure the system to meet the requirements:

Create a configuration profile containing the following keys in the (com.apple.finder) payload type:

```
<key>ProhibitBurn</key>
<true/>
```

Create a configuration profile containing the following keys in the (com.apple.DiscRecording) payload type:

```
<key>BurnSupport</key>
<string>off</string>
```

ID	os_burn_support_disable
----	-------------------------

References	800-53r5	• MP-7
	CCE	• CCE-95170-7

8.6. Disable Installation of Configuration Profiles through the User Interface

Installation of configuration profiles through the user interface *MUST* be disabled and only be permitted through an authorized MDM server.

To check the state of the system, run the following command(s):

```
/usr/bin/osascript -l JavaScript << EOS
$.NSUserDefaults.alloc.initWithSuiteName('com.apple.applicationaccess')\
.objectForKey('allowUIConfigurationProfileInstallation').js
EOS
```

If the result is not **false**, this is a finding.

Remediation Description

Perform the following to configure the system to meet the requirements:

Create a configuration profile containing the following keys in the (com.apple.applicationaccess) payload type:

```
<key>allowUIConfigurationProfileInstallation</key>
<false/>
```

ID	os_config_profile_ui_install_disable	
References	800-53r5	• CM-5
	CCE	• CCE-95177-2

8.7. Disable Dictation

Dictation *MUST* be disabled on Intel based Macs as the feature On Device Dictation is only available on Apple Silicon devices.

To check the state of the system, run the following command(s):

```
/usr/bin/osascript -l JavaScript << EOS
$.NSUserDefaults.alloc.initWithSuiteName('com.apple.applicationaccess')\
.objectForKey('allowDictation').js
```

If the result is not **false**, this is a finding.

Remediation Description

Perform the following to configure the system to meet the requirements:

Create a configuration profile containing the following keys in the (com.apple.applicationaccess) payload type:

```
<key>allowDictation</key>
<false/>
```

ID	os_dictation_disable	
References	800-53r5	• AC-20 • CM-7, CM-7(1) • SC-7(10)
	CCE	• CCE-95180-6

8.8. Disable Erase Content and Settings

Erase Content and Settings *MUST* be disabled.

To check the state of the system, run the following command(s):

```
/usr/bin/osascript -l JavaScript << EOS
$.NSUserDefaults.alloc.initWithSuiteName('com.apple.applicationaccess')\
.objectForKey('allowEraseContentAndSettings').js
EOS
```

If the result is not **false**, this is a finding.

Remediation Description

Perform the following to configure the system to meet the requirements:

Create a configuration profile containing the following keys in the (com.apple.applicationaccess) payload type:

```
<key>allowEraseContentAndSettings</key>
<false/>
```

ID	os_erase_content_and_settings_disable	
References	800-53r5	• CM-7, CM-7(1)
	CCE	• CCE-95185-5

8.9. Disable FileVault Automatic Login

If FileVault is enabled, automatic login *MUST* be disabled, so that both FileVault and login window authentication are required.

The default behavior of macOS when FileVault is enabled is to automatically log in to the computer once successfully passing your FileVault credentials.



DisableFDEAutoLogin does not have to be set on Apple Silicon based macOS systems that are smartcard enforced as smartcards are available at pre-boot.

To check the state of the system, run the following command(s):

```
/usr/bin/osascript -l JavaScript << EOS
$.NSUserDefaults.alloc.initWithSuiteName('com.apple.loginwindow')\
.objectForKey('DisableFDEAutoLogin').js
EOS
```

If the result is not **true**, this is a finding.

Remediation Description

Perform the following to configure the system to meet the requirements:

Create a configuration profile containing the following keys in the (com.apple.loginwindow) payload type:

```
<key>DisableFDEAutoLogin</key>
<true/>
```

ID	os_filevault_autologin_disable	
References	800-53r5	• AC-2(11) • AC-3 • IA-5(13)
	CCE	• CCE-95192-1

8.10. Control Connections to Other Systems via a Deny-All and Allow-by-Exception Firewall Policy

A deny-all and allow-by-exception firewall policy *MUST* be employed for managing connections to other systems.

Organizations *MUST* ensure the built-in packet filter firewall is configured correctly to employ the default deny rule.

Failure to restrict network connectivity to authorized systems permits inbound connections from malicious systems. It also permits outbound connections that may facilitate the exfiltration of data.

If you are using a third-party firewall solution, this setting does not apply.



Configuring the built-in packet filter firewall to employ the default deny rule has the potential to interfere with applications on the system in an unpredictable manner. Information System Security Officers (ISSOs) may make the risk-based decision not to configure the built-in packet filter firewall to employ the default deny rule to avoid losing functionality, but they are advised to first fully weigh the potential risks posed to their organization.

To check the state of the system, run the following command(s):

```
/sbin/pfctl -a '*' -sr &> /dev/null | /usr/bin/grep -c "block drop in all"
```

If the result is not 1, this is a finding.

Remediation Description

Perform the following to configure the system to meet the requirements:



See the firewall supplemental which includes a script that has an example policy to implement this rule.

ID	os_firewall_default_deny_require	
References	800-53r5	• AC-4 • SC-7(5)
	CCE	• CCE-95193-9

8.11. Enable Gatekeeper

Gatekeeper *MUST* be enabled.

Gatekeeper is a security feature that ensures that applications are digitally signed by an Apple-

issued certificate before they are permitted to run. Digital signatures allow the macOS host to verify that the application has not been modified by a malicious third party.

Administrator users will still have the option to override these settings on a case-by-case basis.

To check the state of the system, run the following command(s):

```
/usr/bin/osascript -l JavaScript << EOS
$.NSUserDefaults.alloc.initWithSuiteName('com.apple.systempolicy.control')\
.objectForKey('EnableAssessment').js
EOS
```

If the result is not **true**, this is a finding.

Remediation Description

Perform the following to configure the system to meet the requirements:

Create a configuration profile containing the following keys in the (com.apple.systempolicy.control) payload type:

```
<key>EnableAssessment</key>
<true/>
```

ID	os_gatekeeper_enable	
References	800-53r5	• CM-14 • CM-5 • SI-3 • SI-7(1), SI-7(15)
	CCE	• CCE-95195-4

8.12. Disable Genmoji AI Creation

Apple Intelligence features such as Genmoji *MUST* be disabled.

To check the state of the system, run the following command(s):

```
/usr/bin/osascript -l JavaScript << EOS
$.NSUserDefaults.alloc.initWithSuiteName('com.apple.applicationaccess')\
.objectForKey('allowGenmoji').js
EOS
```


If the result is not **false**, this is a finding.

Remediation Description

Perform the following to configure the system to meet the requirements:

Create a configuration profile containing the following keys in the (com.apple.applicationaccess) payload type:

```
<key>allowGenmoji</key>
<false/>
```

ID	os_genmoji_disable	
References	800-53r5	• CM-7, CM-7(1)
	CCE	• CCE-95196-2

8.13. Disable Handoff

Handoff *MUST* be disabled.

Handoff allows you to continue working on a document or project when the user switches from one Apple device to another. Disabling Handoff prevents data transfers to unauthorized devices.

To check the state of the system, run the following command(s):

```
/usr/bin/osascript -l JavaScript << EOS
$.NSUserDefaults.alloc.initWithSuiteName('com.apple.applicationaccess')\
.objectForKey('allowActivityContinuation').js
EOS
```

If the result is not **false**, this is a finding.

Remediation Description

Perform the following to configure the system to meet the requirements:

Create a configuration profile containing the following keys in the (com.apple.applicationaccess) payload type:

```
<key>allowActivityContinuation</key>
<false/>
```

ID	os_handoff_disable	
References	800-53r5	• AC-20 • AC-3 • CM-7, CM-7(1)
	CCE	• CCE-95199-6

8.14. Secure User's Home Folders

The system *MUST* be configured to prevent access to other user's home folders.

The default behavior of macOS is to allow all valid users access to the top level of every other user's home folder while restricting access only to the Apple default folders within.

To check the state of the system, run the following command(s):

```
/usr/bin/find /System/Volumes/Data/Users -mindepth 1 -maxdepth 1 -type d ! \( -perm 700 -o -perm 711 \) | /usr/bin/grep -v "Shared" | /usr/bin/grep -v "Guest" | /usr/bin/wc -l | /usr/bin/xargs
```

If the result is not **0**, this is a finding.

Remediation Description

Perform the following to configure the system to meet the requirements:

```
IFS=$'\n'
for userDirs in $( /usr/bin/find /System/Volumes/Data/Users -mindepth 1 -maxdepth 1 -type d ! \( -perm 700 -o -perm 711 \) | /usr/bin/grep -v "Shared" | /usr/bin/grep -v "Guest" ); do
    /bin/chmod og-rwx "$userDirs"
done
unset IFS
```

ID	os_home_folders_secure	
References	800-53r5	• AC-6
	CCE	• CCE-95203-6

8.15. Disable the Built-in Web Server

The built-in web server which is managed by launchd is a non-essential service built into macOS and *MUST* be disabled and not running.



The built in web server service is disabled at startup by default macOS.

To check the state of the system, run the following command(s):

```
result="FAIL"
enabled=$(/bin/launchctl print-disabled system | /usr/bin/grep '"org.apache.httpd" =>
enabled')
running=$(/bin/launchctl print system/org.apache.httpd 2>/dev/null)

if [[ -z "$running" ]] && [[ -z "$enabled" ]]; then
    result="PASS"
elif [[ -n "$running" ]]; then
    result=result+" RUNNING"
elif [[ -n "$enabled" ]]; then
    result=result+" ENABLED"
fi
echo $result
```

If the result is not **PASS**, this is a finding.

Remediation Description

Perform the following to configure the system to meet the requirements:

```
/usr/sbin/apachectl stop 2>/dev/null
/bin/launchctl disable system/org.apache.httpd
```

ID	os_httpd_disable	
References	800-53r5	• AC-17 • AC-3
	CCE	• CCE-95204-4

8.16. Disable iCloud Storage Setup during Setup Assistant

The prompt to set up iCloud storage services during Setup Assistant *MUST* be disabled.

The default behavior of macOS is to prompt new users to set up storage in iCloud. Disabling the iCloud storage setup prompt provides organizations more control over the storage of their data.

To check the state of the system, run the following command(s):

```
/usr/bin/osascript -l JavaScript 2>/dev/null << EOS
```

```
$.NSUserDefaults.alloc.initWithSuiteName('com.apple.SetupAssistant.managed')\
.objectForKey('SkipSetupItems').containsObject("iCloudStorage")
EOS
```

If the result is not **true**, this is a finding.

Remediation Description

Perform the following to configure the system to meet the requirements:

Create a configuration profile containing the following keys in the (com.apple.SetupAssistant.managed) payload type:

```
<key>SkipSetupItems</key>
<array>
  <string>iCloudStorage</string>
</array>
```

ID	os_icloud_storage_prompt_disable	
References	800-53r5	• AC-20
	CCE	• CCE-95205-1

8.17. Disable Apple Intelligence Image Playground

Apple Intelligence features such as Image Playground *MUST* be disabled.

To check the state of the system, run the following command(s):

```
/usr/bin/osascript -l JavaScript << EOS
$.NSUserDefaults.alloc.initWithSuiteName('com.apple.applicationaccess')\
.objectForKey('allowImagePlayground').js
EOS
```

If the result is not **false**, this is a finding.

Remediation Description

Perform the following to configure the system to meet the requirements:

Create a configuration profile containing the following keys in the (com.apple.applicationaccess) payload type:

```
<key>allowImagePlayground</key>
```

```
<false/>
```

ID	os_image_playground_disable	
References	800-53r5	• CM-7, CM-7(1)
	CCE	• CCE-95207-7

8.18. Disable iPhone Mirroring

iPhone Mirroring *MUST* be disabled to prevent file transfers to or from unauthorized devices. Disabling iPhone Mirroring also prevents potentially unauthorized applications from appearing as if they are installed on the Mac.

To check the state of the system, run the following command(s):

```
/usr/bin/osascript -l JavaScript << EOS
$.NSUserDefaults.alloc.initWithSuiteName('com.apple.applicationaccess')\
.objectForKey('allowiPhoneMirroring').js
EOS
```

If the result is not **false**, this is a finding.

Remediation Description

Perform the following to configure the system to meet the requirements:

Create a configuration profile containing the following keys in the (com.apple.applicationaccess) payload type:

```
<key>allowiPhoneMirroring</key>
<false/>
```

ID	os_iphone_mirroring_disable	
References	800-53r5	• AC-20 • AC-3 • CM-7, CM-7(1)
	CCE	• CCE-95212-7

8.19. Disable Infrared (IR) support

Infrared (IR) support *MUST* be disabled to prevent users from controlling the system with IR

devices.

By default, if IR is enabled, the system will accept IR control from any remote device.



This is applicable only to models of Mac Mini systems earlier than Mac Mini8,1.

To check the state of the system, run the following command(s):

```
/usr/bin/osascript -l JavaScript << EOS
$.NSUserDefaults.alloc.initWithSuiteName('com.apple.driver.AppleIRController')\
.objectForKey('DeviceEnabled').js
EOS
```

If the result is not **false**, this is a finding.

Remediation Description

Perform the following to configure the system to meet the requirements:



The following settings are in the (com.apple.ManagedClient.preferences) payload. This payload requires the additional settings to be sub-payloads within, containing their defined payload types.

Create a configuration profile containing the following keys in the (com.apple.driver.AppleIRController) payload type:

```
<key>DeviceEnabled</key>
<false/>
```

ID	os_ir_support_disable	
References	800-53r5	• AC-18 • CM-7, CM-7(1)
	CCE	• CCE-95213-5

8.20. Prevent AdminHostInfo from Being Available at Login Window

The system *MUST* be configured to not display sensitive information at the login window. If the key **AdminHostInfo** is configured with a string value, it will allow the HostName, IP Address, and operating system version and build to be displayed when clicking on the clock area of the login window.

Configuring this key to be an integer value, since it expects a string value, will effectively disable

the behavior.



This configuration requires it to be deployed via Managed Preferences rather than directly to com.apple.loginwindow.

To check the state of the system, run the following command(s):

```
/usr/bin/osascript -l JavaScript << EOS
$.NSUserDefaults.alloc.initWithSuiteName('com.apple.loginwindow')\
.integerForKey('AdminHostInfo')
EOS
```

If the result is not -1, this is a finding.

Remediation Description

Perform the following to configure the system to meet the requirements:



The following settings are in the (com.apple.ManagedClient.preferences) payload. This payload requires the additional settings to be sub-payloads within, containing their defined payload types.

Create a configuration profile containing the following keys in the (com.apple.loginwindow) payload type:

```
<key>AdminHostInfo</key>
<integer>-1</integer>
```

ID	os_loginwindow_adminhostinfo_disabled	
References	800-53r5	• AC-11(1)
	CCE	• CCE-95600-3

8.21. Disable Apple Intelligence Mail Smart Replies

Apple Intelligence features such as Mail Smart Replies that use off device AI *MUST* be disabled.

To check the state of the system, run the following command(s):

```
/usr/bin/osascript -l JavaScript << EOS
$.NSUserDefaults.alloc.initWithSuiteName('com.apple.applicationaccess')\
.objectForKey('allowMailSmartReplies').js
EOS
```

If the result is not **false**, this is a finding.

Remediation Description

Perform the following to configure the system to meet the requirements:

Create a configuration profile containing the following keys in the (com.apple.applicationaccess) payload type:

```
<key>allowMailSmartReplies</key>
<false/>
```

ID	os_mail_smart_reply_disable	
References	800-53r5	• AC-20, AC-20(1) • CM-7, CM-7(1) • SC-7(10)
	CCE	• CCE-95222-6

8.22. Disable Apple Intelligence Mail Summary

Apple Intelligence features such as Apple Mail Summary that use off device AI *MUST* be disabled.

To check the state of the system, run the following command(s):

```
/usr/bin/osascript -l JavaScript << EOS
$.NSUserDefaults.alloc.initWithSuiteName('com.apple.applicationaccess')\
.objectForKey('allowMailSummary').js
EOS
```

If the result is not **false**, this is a finding.

Remediation Description

Perform the following to configure the system to meet the requirements:

Create a configuration profile containing the following keys in the (com.apple.applicationaccess) payload type:

```
<key>allowMailSummary</key>
<false/>
```


ID	os_mail_summary_disable	
References	800-53r5	• AC-20, AC-20(1) • CM-7, CM-7(1) • SC-7(10)
	CCE	• CCE-95223-4

8.23. Disable Network File System Service

Support for Network File Systems (NFS) services is non-essential and, therefore, *MUST* be disabled.

To check the state of the system, run the following command(s):

```
isDisabled=$(/sbin/nfsd status | /usr/bin/awk '/nfsd service/ {print $NF}')
if [[ "$isDisabled" == "disabled" ]] && [[ -z $(/usr/bin/pgrep nfsd) ]]; then
    echo "pass"
else
    echo "fail"
fi
```

If the result is not **pass**, this is a finding.

Remediation Description

Perform the following to configure the system to meet the requirements:

```
/bin/launchctl disable system/com.apple.nfsd
/bin/rm -rf /etc/exports
```

The system may need to be restarted for the update to take effect.

ID	os_nfsd_disable	
References	800-53r5	• AC-17 • AC-3
	CCE	• CCE-95235-8

8.24. Disable Apple Intelligence Notes Transcription

Apple Intelligence features such as Notes Transcription that use off device AI *MUST* be disabled.

To check the state of the system, run the following command(s):

```
/usr/bin/osascript -l JavaScript << EOS
$.NSUserDefaults.alloc.initWithSuiteName('com.apple.applicationaccess')\
.objectForKey('allowNotesTranscription').js
EOS
```

If the result is not **false**, this is a finding.

Remediation Description

Perform the following to configure the system to meet the requirements:

Create a configuration profile containing the following keys in the (com.apple.applicationaccess) payload type:

```
<key>allowNotesTranscription</key>
<false/>
```

ID	os_notes_transcription_disable	
References	800-53r5	• AC-20, AC-20(1) • CM-7, CM-7(1) • SC-7(10)
	CCE	• CCE-95238-2

8.25. Disable Apple Intelligence Notes Transcription Summary

Apple Intelligence features such as Notes Transcription Summary that use off device AI *MUST* be disabled.

To check the state of the system, run the following command(s):

```
/usr/bin/osascript -l JavaScript << EOS
$.NSUserDefaults.alloc.initWithSuiteName('com.apple.applicationaccess')\
.objectForKey('allowNotesTranscriptionSummary').js
EOS
```

If the result is not **false**, this is a finding.

Remediation Description

Perform the following to configure the system to meet the requirements:

Create a configuration profile containing the following keys in the (com.apple.applicationaccess) payload type:

```
<key>allowNotesTranscriptionSummary</key>
<false/>
```

ID	os_notes_transcription_summary_disable	
References	800-53r5	• AC-20, AC-20(1) • CM-7, CM-7(1) • SC-7(10)
	CCE	• CCE-95239-0

8.26. Enforce On Device Dictation

Dictation *MUST* be restricted to on device only to prevent potential data exfiltration.

The information system *MUST* be configured to provide only essential capabilities.



This rule only applies to Apple Silicon devices.

To check the state of the system, run the following command(s):

```
/usr/bin/osascript -l JavaScript << EOS
$.NSUserDefaults.alloc.initWithSuiteName('com.apple.applicationaccess')\
.objectForKey('forceOnDeviceOnlyDictation').js
EOS
```

If the result is not **true**, this is a finding.

Remediation Description

Perform the following to configure the system to meet the requirements:

Create a configuration profile containing the following keys in the (com.apple.applicationaccess) payload type:

```
<key>forceOnDeviceOnlyDictation</key>
<true/>
```

ID	os_on_device_dictation_enforce
----	--------------------------------

References	800-53r5	• AC-20 • CM-7, CM-7(1) • SC-7(10)
	CCE	• CCE-95247-3

8.27. Disable Proximity Based Password Sharing Requests

Proximity based password sharing requests *MUST* be disabled.

The default behavior of macOS is to allow users to request passwords from other known devices (macOS and iOS). This feature *MUST* be disabled to prevent passwords from being shared.

To check the state of the system, run the following command(s):

```
/usr/bin/osascript -l JavaScript << EOS
$.NSUserDefaults.alloc.initWithSuiteName('com.apple.applicationaccess')\
.objectForKey('allowPasswordProximityRequests').js
EOS
```

If the result is not **false**, this is a finding.

Remediation Description

Perform the following to configure the system to meet the requirements:

Create a configuration profile containing the following keys in the (com.apple.applicationaccess) payload type:

```
<key>allowPasswordProximityRequests</key>
<false/>
```

ID	os_password_proximity_disable	
References	800-53r5	• IA-5
	CCE	• CCE-95251-5

8.28. Disable Password Sharing

Password Sharing *MUST* be disabled.

The default behavior of macOS is to allow users to share a password over Airdrop between other

macOS and iOS devices. This feature *MUST* be disabled to prevent passwords from being shared.

To check the state of the system, run the following command(s):

```
/usr/bin/osascript -l JavaScript << EOS
$.NSUserDefaults.alloc.initWithSuiteName('com.apple.applicationaccess')\
.objectForKey('allowPasswordSharing').js
EOS
```

If the result is not **false**, this is a finding.

Remediation Description

Perform the following to configure the system to meet the requirements:

Create a configuration profile containing the following keys in the (com.apple.applicationaccess) payload type:

```
<key>allowPasswordSharing</key>
<false/>
```

ID	os_password_sharing_disable	
References	800-53r5	• IA-5
	CCE	• CCE-95252-3

8.29. Disable Photos Enhanced Visual Search

Enhanced Visual Search *MUST* be disabled in the Photos app.

The information system *MUST* be configured to provide only essential capabilities. Disabling Enhanced Visual Search will mitigate the risk of unwanted data being sent to Apple.

To check the state of the system, run the following command(s):

```
/usr/bin/osascript -l JavaScript << EOS
$.NSUserDefaults.alloc.initWithSuiteName('com.apple.photos.shareddefaults')\
.objectForKey('IPXDefaultEnhancedVisualSearchEnabled').js
EOS
```

If the result is not **false**, this is a finding.

Remediation Description

Perform the following to configure the system to meet the requirements:

Create a configuration profile containing the following keys in the (com.apple.photos.shareddefaults) payload type:

```
<key>IPXDefaultEnhancedVisualSearchEnabled</key>
<false/>
```

ID	os_photos_enhanced_search_disable	
References	800-53r5	• AC-20, AC-20(1) • CM-7, CM-7(1) • SC-7(10)
	CCE	• CCE-95254-9

8.30. Display Policy Banner at Login Window

Displaying a standardized and approved use notification before granting access to the operating system ensures that users are provided with privacy and security notification verbiage that is consistent with applicable federal laws, Executive Orders, directives, policies, regulations, standards, and guidance.

System use notifications are required only for access via login interfaces with human users and are not required when such human interfaces do not exist.

The policy banner will show if a "PolicyBanner.rtf" or "PolicyBanner.rtf.d" exists in the "/Library/Security" folder.

The banner text of the document *MUST* read:

You are accessing a U.S. Government information system, which includes: 1) this computer, 2) this computer network, 3) all Government-furnished computers connected to this network, and 4) all Government-furnished devices and storage media attached to this network or to a computer on this network. You understand and consent to the following: you may access this information system for authorized use only; unauthorized use of the system is prohibited and subject to criminal and civil penalties; you have no reasonable expectation of privacy regarding any communication or data transiting or stored on this information system at any time and for any lawful Government purpose, the Government may monitor, intercept, audit, and search and seize any communication or data transiting or stored on this information system; and any communications or data transiting or stored on this information system may be disclosed or used for any lawful Government purpose. This information system may contain Controlled Unclassified Information (CUI) that is subject to safeguarding or dissemination controls in accordance with law, regulation, or Government-wide policy. Accessing and using this system indicates your understanding of this warning.

To check the state of the system, run the following command(s):

```
/bin/ls -ld /Library/Security/PolicyBanner.rtf* | /usr/bin/wc -l | /usr/bin/tr -d ' '
```

If the result is not 1, this is a finding.

Remediation Description

Perform the following to configure the system to meet the requirements:

```
bannerText="You are accessing a U.S. Government information system, which includes: 1) this computer, 2) this computer network, 3) all Government-furnished computers connected to this network, and 4) all Government-furnished devices and storage media attached to this network or to a computer on this network. You understand and consent to the following: you may access this information system for authorized use only; unauthorized use of the system is prohibited and subject to criminal and civil penalties; you have no reasonable expectation of privacy regarding any communication or data transiting or stored on this information system at any time and for any lawful Government purpose, the Government may monitor, intercept, audit, and search and seize any communication or data transiting or stored on this information system; and any communications or data transiting or stored on this information system may be disclosed or used for any lawful Government purpose. This information system may contain Controlled Unclassified Information (CUI) that is subject to safeguarding or dissemination controls in accordance with law, regulation, or Government-wide policy. Accessing and using this system indicates your understanding of this warning."
/bin/mkdir /Library/Security/PolicyBanner.rtf
/usr/bin/textutil -convert rtf -output /Library/Security/PolicyBanner.rtf/TXT.rtf -stdin <<EOF
$bannerText
EOF
```

ID	os_policy_banner_loginwindow_enforce	
References	800-53r5	• AC-8
	CCE	• CCE-95257-2

8.31. Display Policy Banner at Remote Login

Remote login service *MUST* be configured to display a policy banner at login.

Displaying a standardized and approved use notification before granting access to the operating system ensures that users are provided with privacy and security notification verbiage that is consistent with applicable federal laws, Executive Orders, directives, policies, regulations, standards, and guidance.

System use notifications are required only for access via login interfaces with human users and are not required when such human interfaces do not exist.

To check the state of the system, run the following command(s):

```
bannerText="You are accessing a U.S. Government (USG) Information System (IS) that is
provided for USG-authorized use only. By using this IS (which includes any device
attached to this IS), you consent to the following conditions:
-The USG routinely intercepts and monitors communications on this IS for purposes
including, but not limited to, penetration testing, COMSEC monitoring, network
operations and defense, personnel misconduct (PM), law enforcement (LE), and
counterintelligence (CI) investigations.
-At any time, the USG may inspect and seize data stored on this IS.
-Communications using, or data stored on, this IS are not private, are subject to
routine monitoring, interception, and search, and may be disclosed or used for any USG
authorized purpose.
-This IS includes security measures (e.g., authentication and access controls) to
protect USG interests--not for your personal benefit or privacy.
-Notwithstanding the above, using this IS does not constitute consent to PM, LE or CI
investigative searching or monitoring of the content of privileged communications, or
work product, related to personal representation or services by attorneys,
psychotherapists, or clergy, and their assistants. Such communications and work
product are private and confidential. See User Agreement for details."
test "$(cat /etc/banner)" = "$bannerText" && echo "1" || echo "0"
```

If the result is not 1, this is a finding.

Remediation Description

Perform the following to configure the system to meet the requirements:

```
bannerText="You are accessing a U.S. Government (USG) Information System (IS) that
is provided for USG-authorized use only. By using this IS (which includes any
device attached to this IS), you consent to the following conditions:
-The USG routinely intercepts and monitors communications on this IS for purposes
including, but not limited to, penetration testing, COMSEC monitoring, network
operations and defense, personnel misconduct (PM), law enforcement (LE), and
counterintelligence (CI) investigations.
-At any time, the USG may inspect and seize data stored on this IS.
-Communications using, or data stored on, this IS are not private, are subject to
routine monitoring, interception, and search, and may be disclosed or used for any
USG authorized purpose.
-This IS includes security measures (e.g., authentication and access controls) to
protect USG interests--not for your personal benefit or privacy.
-Notwithstanding the above, using this IS does not constitute consent to PM, LE or
CI investigative searching or monitoring of the content of privileged
communications, or work product, related to personal representation or services by
attorneys, psychotherapists, or clergy, and their assistants. Such communications
and work product are private and confidential. See User Agreement for details."
```



```
/bin/echo "${bannerText}" > /etc/banner
```

ID	os_policy_banner_ssh_configure	
References	800-53r5	• AC-8
	CCE	• CCE-95258-0

8.32. Enforce SSH to Display Policy Banner

SSH *MUST* be configured to display a policy banner.

Displaying a standardized and approved use notification before granting access to the operating system ensures that users are provided with privacy and security notification verbiage that is consistent with applicable federal laws, Executive Orders, directives, policies, regulations, standards, and guidance.

System use notifications are required only for access via login interfaces with human users and are not required when such human interfaces do not exist



/etc/ssh/sshd_config will be automatically modified to its original state following any update or major upgrade to the operating system.

To check the state of the system, run the following command(s):

```
/usr/sbin/sshd -G | /usr/bin/grep -c "^banner /etc/banner"
```

If the result is not 1, this is a finding.

Remediation Description

Perform the following to configure the system to meet the requirements:

```
include_dir=$(/usr/bin/awk '/^Include/ {print $2}' /etc/ssh/sshd_config |
/usr/bin/tr -d '*')

if [[ -z $include_dir ]]; then
    /usr/bin/sed -i.bk "1s/.*/Include \/etc\/ssh\/sshd_config.d\/\*/"
    /etc/ssh/sshd_config
fi

/usr/bin/grep -qxF 'banner /etc/banner' "${include_dir}01-mscp-sshd.conf"
2>/dev/null || echo "banner /etc/banner" >> "${include_dir}01-mscp-sshd.conf"

for file in $(ls $include_dir); do
    if [[ "$file" == "100-macos.conf" ]]; then
```

```

        continue
    fi
    if [[ "$file" == "01-mscp-sshd.conf" ]]; then
        break
    fi
    /bin/mv ${include_dir}${file} ${include_dir}20-${file}
done

```

ID	os_policy_banner_ssh_enforce	
References	800-53r5	• AC-8
	CCE	• CCE-95259-8

8.33. Disable Privacy Setup Services During Setup Assistant

The prompt for Privacy Setup services during Setup Assistant *MUST* be disabled.

Organizations *MUST* apply organization-wide configuration settings. The macOS Privacy Setup services prompt guides new users through enabling their own specific privacy settings; this is not essential and, therefore, *MUST* be disabled to prevent against the risk of individuals electing privacy settings with the potential to override organization-wide settings.

To check the state of the system, run the following command(s):

```

/usr/bin/osascript -l JavaScript 2>/dev/null << EOS
$.NSUserDefaults.alloc.initWithSuiteName('com.apple.SetupAssistant.managed')\
.objectForKey('SkipSetupItems').containsObject("Privacy")
EOS

```

If the result is not **true**, this is a finding.

Remediation Description

Perform the following to configure the system to meet the requirements:

Create a configuration profile containing the following keys in the (com.apple.SetupAssistant.managed) payload type:

```

<key>SkipSetupItems</key>
<array>
    <string>Privacy</string>
</array>

```

ID	os_privacy_setup_prompt_disable	
References	800-53r5	• CM-7, CM-7(1)
	CCE	• CCE-95267-1

8.34. Enforce Rapid Security Response Mechanism

Rapid security response mechanism *MUST* be enabled.

To check the state of the system, run the following command(s):

```
/usr/bin/osascript -l JavaScript << EOS
$.NSUserDefaults.alloc.initWithSuiteName('com.apple.applicationaccess')\
.objectForKey('allowRapidSecurityResponseInstallation').js
EOS
```

If the result is not **true**, this is a finding.

Remediation Description

Perform the following to configure the system to meet the requirements:

Create a configuration profile containing the following keys in the (com.apple.applicationaccess) payload type:

```
<key>allowRapidSecurityResponseInstallation</key>
<true/>
```

ID	os_rapid_security_response_allow	
References	800-53r5	• SI-2, SI-2(5) • SI-3
	CCE	• CCE-95272-1

8.35. Disable User Ability from Being Able to Undo Rapid Security Responses

Rapid security response (RSR) mechanism *MUST* be enabled and the ability for the user to disable RSR *MUST* be disabled.

To check the state of the system, run the following command(s):

```
/usr/bin/osascript -l JavaScript << EOS
```

```
$.NSUserDefaults.alloc.initWithSuiteName('com.apple.applicationaccess')\
.objectForKey('allowRapidSecurityResponseRemoval').js
EOS
```

If the result is not **false**, this is a finding.

Remediation Description

Perform the following to configure the system to meet the requirements:

Create a configuration profile containing the following keys in the (com.apple.applicationaccess) payload type:

```
<key>allowRapidSecurityResponseRemoval</key>
<false/>
```

ID	os_rapid_security_response_removal_disable	
References	800-53r5	• SI-2, SI-2(5) • SI-3
	CCE	• CCE-95273-9

8.36. Enable Recovery Lock

A recovery lock password *MUST* be enabled and set.

Single user mode, recovery mode, the Startup Manager, and several other tools are available on macOS by holding down specific key combinations during startup. Setting a recovery lock restricts access to these tools.



Recovery lock passwords are not supported on Intel devices. This rule is only applicable to Apple Silicon devices.

To check the state of the system, run the following command(s):

```
/usr/libexec/mdmclient QuerySecurityInfo 2>/dev/null | /usr/bin/grep -c
"IsRecoveryLockEnabled = 1"
```

If the result is not **1**, this is a finding.

Remediation Description

Perform the following to configure the system to meet the requirements:



The SetRecoveryLock command can be used to set a Recovery Lock password and must be from your MDM.

ID	os_recovery_lock_enable	
References	800-53r5	• AC-6
	CCE	• CCE-95277-0

8.37. Disable Root Login

To assure individual accountability and prevent unauthorized access, logging in as root at the login window *MUST* be disabled.

The macOS system *MUST* require individuals to be authenticated with an individual authenticator prior to using a group authenticator, and administrator users *MUST* never log in directly as root.

To check the state of the system, run the following command(s):

```
/usr/bin/dscl . -read /Users/root UserShell 2>&1 | /usr/bin/grep -c "/usr/bin/false"
```

If the result is not 1, this is a finding.

Remediation Description

Perform the following to configure the system to meet the requirements:

```
/usr/bin/dscl . -create /Users/root UserShell /usr/bin/false
```

ID	os_root_disable	
References	800-53r5	• IA-2, IA-2(5)
	CCE	• CCE-95282-0

8.38. Disable Apple Intelligence Safari Reader Summary

Apple Intelligence features such as Safari Reader Summary that use off device AI *MUST* be disabled.

To check the state of the system, run the following command(s):

```
/usr/bin/osascript -l JavaScript << EOS
$.NSUserDefaults.alloc.initWithSuiteName('com.apple.applicationaccess')\n
```

```
.objectForKey('allowSafariSummary').js
EOS
```

If the result is not **false**, this is a finding.

Remediation Description

Perform the following to configure the system to meet the requirements:

Create a configuration profile containing the following keys in the (com.apple.applicationaccess) payload type:

```
<key>allowSafariSummary</key>
<false/>
```

ID	os_safari_reader_summary_disable	
References	800-53r5	• AC-20, AC-20(1) • CM-7, CM-7(1) • SC-7(10)
	CCE	• CCE-95286-1

8.39. Enforce Screen Saver at Login Window

A default screen saver *MUST* be configured to display at the login window and *MUST* not display any sensitive information.

To check the state of the system, run the following command(s):

```
/usr/bin/osascript -l JavaScript << EOS
$.NSUserDefaults.alloc.initWithSuiteName('com.apple.screensaver')\
.objectForKey('moduleName').js
EOS
```

If the result is not **Tahoe**, this is a finding.

Remediation Description

Perform the following to configure the system to meet the requirements:

Create a configuration profile containing the following keys in the (com.apple.screensaver) payload type:

```
<key>moduleName</key>
<string>Tahoe</string>
```

ID	os_screensaver_loginwindow_enforce	
References	800-53r5	• AC-11(1)
	CCE	• CCE-95290-3

8.40. Ensure System Integrity Protection is Enabled

System Integrity Protection (SIP) *MUST* be enabled.

SIP is vital to protecting the integrity of the system as it prevents malicious users and software from making unauthorized and/or unintended modifications to protected files and folders; ensures the presence of an audit record generation capability for defined auditable events for all operating system components; protects audit tools from unauthorized access, modification, and deletion; restricts the root user account and limits the actions that the root user can perform on protected parts of the macOS; and prevents non-privileged users from granting other users direct access to the contents of their home directories and folders.



SIP is enabled by default in macOS.

To check the state of the system, run the following command(s):

```
/usr/bin/csrutil status | /usr/bin/grep -c 'System Integrity Protection status:
enabled.'
```

If the result is not 1, this is a finding.

Remediation Description

Perform the following to configure the system to meet the requirements:

```
/usr/bin/csrutil enable
```



To re-enable "System Integrity Protection", boot the affected system into "Recovery" mode, launch "Terminal" from the "Utilities" menu, and run the command.

ID	os_sip_enable
-----------	---------------

References	800-53r5	• AC-3 • AU-9, AU-9(3) • CM-5, CM-5(6) • SC-4 • SI-2 • SI-7
	CCE	• CCE-95298-6

8.41. Disable Siri Setup during Setup Assistant

The prompt for Siri during Setup Assistant *MUST* be disabled.

Organizations *MUST* apply organization-wide configuration settings. The macOS Siri Assistant Setup prompt guides new users through enabling their own specific Siri settings; this is not essential and, therefore, *MUST* be disabled to prevent against the risk of individuals electing Siri settings with the potential to override organization-wide settings.

To check the state of the system, run the following command(s):

```
/usr/bin/osascript -l JavaScript 2>/dev/null << EOS
$.NSUserDefaults.alloc.initWithSuiteName('com.apple.SetupAssistant.managed')\
.objectForKey('SkipSetupItems').containsObject("Siri")
EOS
```

If the result is not **true**, this is a finding.

Remediation Description

Perform the following to configure the system to meet the requirements:

Create a configuration profile containing the following keys in the (com.apple.SetupAssistant.managed) payload type:

```
<key>SkipSetupItems</key>
<array>
  <string>Siri</string>
</array>
```

ID	os_siri_prompt_disable
----	------------------------

References	800-53r5	• AC-20 • CM-7, CM-7(1)
	CCE	• CCE-95299-4

8.42. Disable Apple Intelligence During Setup Assistant

The prompt for setting up Apple Intelligence during Setup Assistant *MUST* be disabled.

To check the state of the system, run the following command(s):

```
/usr/bin/osascript -l JavaScript 2>/dev/null << EOS
$.NSUserDefaults.alloc.initWithSuiteName('com.apple.SetupAssistant.managed')\
.objectForKey('SkipSetupItems').containsObject("Intelligence")
EOS
```

If the result is not **true**, this is a finding.

Remediation Description

Perform the following to configure the system to meet the requirements:

Create a configuration profile containing the following keys in the (com.apple.SetupAssistant.managed) payload type:

```
<key>SkipSetupItems</key>
<array>
  <string>Intelligence</string>
</array>
```

ID	os_skip_apple_intelligence_enable	
References	800-53r5	• AC-20 • AC-4 • CM-7
	CCE	• CCE-95603-7

8.43. Disable Screen Time Prompt During Setup Assistant

The prompt for Screen Time setup during Setup Assistant *MUST* be disabled.

To check the state of the system, run the following command(s):

```
/usr/bin/osascript -l JavaScript 2>/dev/null << EOS
$.NSUserDefaults.alloc.initWithSuiteName('com.apple.SetupAssistant.managed')\
.objectForKey('SkipSetupItems').containsObject("ScreenTime")
EOS
```

If the result is not **true**, this is a finding.

Remediation Description

Perform the following to configure the system to meet the requirements:

Create a configuration profile containing the following keys in the (com.apple.SetupAssistant.managed) payload type:

```
<key>SkipSetupItems</key>
<array>
  <string>ScreenTime</string>
</array>
```

ID	os_skip_screen_time_prompt_enable	
References	800-53r5	• CM-7, CM-7(1)
	CCE	• CCE-95300-0

8.44. Disable Unlock with Apple Watch During Setup Assistant

The prompt for Apple Watch unlock setup during Setup Assistant *MUST* be disabled.

Disabling Apple watches is a necessary step to ensuring that the information system retains a session lock until the user reestablishes access using an authorized identification and authentication procedures.

To check the state of the system, run the following command(s):

```
/usr/bin/osascript -l JavaScript 2>/dev/null << EOS
$.NSUserDefaults.alloc.initWithSuiteName('com.apple.SetupAssistant.managed')\
.objectForKey('SkipSetupItems').containsObject("WatchMigration")
EOS
```

If the result is not **true**, this is a finding.

Remediation Description

Perform the following to configure the system to meet the requirements:

Create a configuration profile containing the following keys in the (com.apple.SetupAssistant.managed) payload type:

```
<key>SkipSetupItems</key>
<array>
  <string>WatchMigration</string>
</array>
```

ID	os_skip_unlock_with_watch_enable	
References	800-53r5	• AC-20
	CCE	• CCE-95301-8

8.45. Limit SSH to FIPS Compliant Connections

SSH *MUST* be configured to limit the Ciphers, HostbasedAcceptedAlgorithms, HostKeyAlgorithms, KexAlgorithms, MACs, PubkeyAcceptedAlgorithms, CASignatureAlgorithms to algorithms that are FIPS 140 validated.

FIPS 140-3 is the current standard for validating that mechanisms used to access cryptographic modules utilize authentication that meet federal requirements.

Operating systems utilizing encryption *MUST* use FIPS validated mechanisms for authenticating to cryptographic modules.



For more information on FIPS compliance with the version of SSH included in the macOS, the manual page `apple_ssh_and_fips` has additional information.



On macOS 15.2 and higher the SSH configuration can be reset to the macOS default by running `/usr/libexec/reset-ssh-configuration`.

To check the state of the system, run the following command(s):

```
fips_ssh_config=("Ciphers aes128-gcm@openssh.com" "HostbasedAcceptedAlgorithms ecdsa-sha2-nistp256,ecdsa-sha2-nistp256-cert-v01@openssh.com" "HostKeyAlgorithms ecdsa-sha2-nistp256-cert-v01@openssh.com,sk-ecdsa-sha2-nistp256-cert-v01@openssh.com,ecdsa-sha2-nistp256,sk-ecdsa-sha2-nistp256@openssh.com" "KexAlgorithms ecdh-sha2-nistp256" "MACs hmac-sha2-256-etm@openssh.com,hmac-sha2-256" "PubkeyAcceptedAlgorithms ecdsa-sha2-nistp256,ecdsa-sha2-nistp256-cert-v01@openssh.com,sk-ecdsa-sha2-nistp256-cert-v01@openssh.com" "CASignatureAlgorithms ecdsa-sha2-nistp256,sk-ecdsa-sha2-nistp256@openssh.com")
total=0
ret="pass"
for config in $fips_ssh_config; do
```

```

if [[ "$ret" == "fail" ]]; then
    break
fi
for u in $(/usr/bin/dscl . list /users shell | /usr/bin/egrep -v
'(^_)|(root)|(/usr/bin/false)' | /usr/bin/awk '{print $1}'); do
    sshCheck=$(/usr/bin/sudo -u $u /usr/bin/ssh -G . | /usr/bin/grep -ci "$config")
    if [[ "$sshCheck" == "0" ]]; then
        ret="fail"
        break
    fi
done
done
echo $ret

```

If the result is not **pass**, this is a finding.

Remediation Description

Perform the following to configure the system to meet the requirements:

```

if [ -f /etc/ssh/crypto.conf ] && /usr/bin/grep -q "Include /etc/ssh/crypto.conf"
/etc/ssh/ssh_config.d/100-macos.conf 2>/dev/null; then
    /bin/ln -fs /etc/ssh/crypto/fips.conf /etc/ssh/crypto.conf
fi
include_dir=$(/usr/bin/awk '/^Include/ {print $2}' /etc/ssh/ssh_config |
/usr/bin/tr -d '*')

fips_ssh_config=("Ciphers aes128-gcm@openssh.com" "HostbasedAcceptedAlgorithms
ecdsa-sha2-nistp256,ecdsa-sha2-nistp256-cert-v01@openssh.com" "HostKeyAlgorithms
ecdsa-sha2-nistp256-cert-v01@openssh.com,sk-ecdsa-sha2-nistp256-cert-
v01@openssh.com,ecdsa-sha2-nistp256,sk-ecdsa-sha2-nistp256@openssh.com"
"KexAlgorithms ecdh-sha2-nistp256" "MACs hmac-sha2-256-etm@openssh.com,hmac-sha2-
256" "PubkeyAcceptedAlgorithms ecdsa-sha2-nistp256,ecdsa-sha2-nistp256-cert-
v01@openssh.com,sk-ecdsa-sha2-nistp256-cert-v01@openssh.com"
"CASignatureAlgorithms ecdsa-sha2-nistp256,sk-ecdsa-sha2-nistp256@openssh.com")
for ssh_config in $fips_ssh_config; do
    ssh_setting=$(echo $ssh_config | /usr/bin/cut -d " " -f1)
    /usr/bin/grep -qEi "^$ssh_setting" "${include_dir}01-mscp-ssh.conf" &&
/usr/bin/sed -i "" "s/^$ssh_setting.*/${ssh_config}/" "${include_dir}01-mscp-
ssh.conf" || echo "$ssh_config" >> "${include_dir}01-mscp-ssh.conf"
    for u in $(/usr/bin/dscl . list /users shell | /usr/bin/egrep -v
'(^_)|(root)|(/usr/bin/false)' | /usr/bin/awk '{print $1}'); do
        config=$(/usr/bin/sudo -u $u /usr/bin/ssh -Gv . 2>&1)
        configfiles=$(echo "$config" | /usr/bin/awk '/Reading configuration data/
{print $NF}' | /usr/bin/tr -d '\r')
        configarray=( ${configfiles} )
        if ! echo $config | /usr/bin/grep -q -i "$ssh_config" ; then
            for c in $configarray; do
                if [[ "$c" == "/etc/ssh/crypto.conf" ]]; then

```

```

        continue
    fi

    /usr/bin/sudo -u $u /usr/bin/grep -qEi "^$ssh_setting" "$c" &&
    /usr/bin/sed -i "" "s/^$ssh_setting.*/${ssh_config}/I" "$c"
    if [[ "$c" =~ ".ssh/config" ]]; then
        if /usr/bin/grep -qEi "$ssh_setting" "$c" 2> /dev/null; then
            old_file=$(cat ~$u/.ssh/config)
            echo "$ssh_config" > ~$u/.ssh/config
            echo "$old_file" >> ~$u/.ssh/config
        fi
    fi
done
fi
done
done

```

ID	os_ssh_fips_compliant	
References	800-53r5	• AC-17(2) • IA-7 • SC-13 • SC-8(1)
	CCE	• CCE-95304-2

8.46. Set SSH Active Server Alive Maximum to 0

SSH *MUST* be configured with an Active Server Alive Maximum Count set to 0. Terminating an idle session within a short time period reduces the window of opportunity for unauthorized personnel to take control of a management session enabled on the console or console port that has been left unattended. In addition, quickly terminating an idle session or an incomplete login attempt will also free up resources committed by the managed network element.



/etc/ssh/ssh_config will be automatically modified to its original state following any update or major upgrade to the operating system.



On macOS 15.2 and higher the SSH configuration can be reset to the macOS default by running /usr/libexec/reset-ssh-configuration.

To check the state of the system, run the following command(s):

```

ret="pass"
for u in $(/usr/bin/dscl . -list /Users UniqueID | /usr/bin/awk '$2 > 500 {print $1}'); do
    sshCheck=$(/usr/bin/sudo -u $u /usr/bin/ssh -G . | /usr/bin/grep -c

```

```

"^serveralivecountmax 0")
  if [[ "$sshCheck" == "0" ]]; then
    ret="fail"
    break
  fi
done
/bin/echo $ret

```

If the result is not **pass**, this is a finding.

Remediation Description

Perform the following to configure the system to meet the requirements:

```

include_dir=$(/usr/bin/awk '/^Include/ {print $2}' /etc/ssh/ssh_config |
/usr/bin/tr -d '*')

ssh_config=("ServerAliveCountMax 0")

ssh_setting=$(echo $ssh_config | /usr/bin/cut -d " " -f1)
/usr/bin/grep -qEi "^$ssh_setting" "${include_dir}01-mscp-ssh.conf" &&
/usr/bin/sed -i "" "s/^$ssh_setting.*/${ssh_config}/" "${include_dir}01-mscp-
ssh.conf" || echo "$ssh_config" >> "${include_dir}01-mscp-ssh.conf"
for u in $(/usr/bin/dscl . list /users shell | /usr/bin/egrep -v
'(^_)|(root)|(/usr/bin/false)' | /usr/bin/awk '{print $1}'); do
  config=$(/usr/bin/sudo -u $u /usr/bin/ssh -Gv . 2>&1)
  configfiles=$(echo "$config" | /usr/bin/awk '/Reading configuration data/ {print
$NF}' | /usr/bin/tr -d '\r')
  configarray=( ${!(f)configfiles} )
  if ! echo $config | /usr/bin/grep -q -i "$ssh_config" ; then
    for c in $configarray; do
      if [[ "$c" == "/etc/ssh/crypto.conf" ]]; then
        continue
      fi

      /usr/bin/sudo -u $u /usr/bin/grep -qEi "^$ssh_setting" "$c" && /usr/bin/sed
-i "" "s/^$ssh_setting.*/${ssh_config}/I" "$c"
      if [[ "$c" =~ ".ssh/config" ]]; then
        if /usr/bin/grep -qEi "$ssh_setting" "$c" 2> /dev/null; then
          old_file=$(cat ~$u/.ssh/config)
          echo "$ssh_config" > ~$u/.ssh/config
          echo "$old_file" >> ~$u/.ssh/config
        fi
      fi
    done
  fi
done

```

ID	os_ssh_server_alive_count_max_configure	
References	800-53r5	• SC-10
	CCE	• CCE-95305-9

8.47. Configure SSH ServerAliveInterval option set to 900

SSH *MUST* be configured with an Active Server Alive Maximum Count set to 900.

Setting the Active Server Alive Maximum Count to 900 will log users out after a 900 seconds interval of inactivity.



/etc/ssh/ssh_config will be automatically modified to its original state following any update or major upgrade to the operating system.



On macOS 15.2 and higher the SSH configuration can be reset to the macOS default by running /usr/libexec/reset-ssh-configuration.

To check the state of the system, run the following command(s):

```
ret="pass"
for u in $(/usr/bin/dscl . -list /Users UniqueID | /usr/bin/awk '$2 > 500 {print $1}'); do
    sshCheck=$(/usr/bin/sudo -u $u /usr/bin/ssh -G . | /usr/bin/grep -c
"^serveraliveinterval 900")
    if [[ "$sshCheck" == "0" ]]; then
        ret="fail"
        break
    fi
done
/bin/echo $ret
```

If the result is not **pass**, this is a finding.

Remediation Description

Perform the following to configure the system to meet the requirements:

```
include_dir=$(/usr/bin/awk '/^Include/ {print $2}' /etc/ssh/ssh_config |
/usr/bin/tr -d '*')

ssh_config_string=("ServerAliveInterval 900")
for ssh_config in $ssh_config_string; do
    ssh_setting=$(echo $ssh_config | /usr/bin/cut -d " " -f1)
    /usr/bin/grep -qEi "$ssh_setting" "${include_dir}01-mscp-ssh.conf" &&
```

```

/usr/bin/sed -i "" "s/^$ssh_setting.*/${ssh_config}/" "${include_dir}01-mscp-
ssh.conf" || echo "$ssh_config" >> "${include_dir}01-mscp-ssh.conf"
for u in $(/usr/bin/dscl . list /users shell | /usr/bin/egrep -v
'(^_|)(root)|(/usr/bin/false)' | /usr/bin/awk '{print $1}'); do
    config=$(/usr/bin/sudo -u $u /usr/bin/ssh -Gv . 2>&1)
    configfiles=$(echo "$config" | /usr/bin/awk '/Reading configuration data/
{print $NF}') | /usr/bin/tr -d '\r')
    configarray=( ${!(f)configfiles} )
    if ! echo $config | /usr/bin/grep -q -i "$ssh_config" ; then
        for c in $configarray; do
            if [[ "$c" == "/etc/ssh/crypto.conf" ]]; then
                continue
            fi

            /usr/bin/sudo -u $u /usr/bin/grep -qEi "^$ssh_setting" "$c" &&
/usr/bin/sed -i "" "s/^$ssh_setting.*/${ssh_config}/I" "$c"
            if [[ "$c" =~ ".ssh/config" ]]; then
                if /usr/bin/grep -qEi "$ssh_setting" "$c" 2> /dev/null; then
                    old_file=$(cat ~$u/.ssh/config)
                    echo "$ssh_config" > ~$u/.ssh/config
                    echo "$old_file" >> ~$u/.ssh/config
                fi
            fi
        done
    fi
done
done
done

```

ID	os_ssh_server_alive_interval_configure	
References	800-53r5	• AC-12 • SC-10
	CCE	• CCE-95306-7

8.48. Configure SSHD Channel Timeout to session:*=900

If SSHD is enabled it *MUST* be configured with session ChannelTime out set to session:*=900.

This will set the time out when the session is inactive.



/etc/ssh/sshd_config will be automatically modified to its original state following any update or major upgrade to the operating system.



On macOS 15.2 and higher the SSH configuration can be reset to the macOS default by running /usr/libexec/reset-ssh-configuration.

To check the state of the system, run the following command(s):

```
/usr/sbin/sshd -G | /usr/bin/awk '/channeltimeout/{print $2}'
```

If the result is not **session:=900***, this is a finding.

Remediation Description

Perform the following to configure the system to meet the requirements:

```
include_dir=$(/usr/bin/awk '/^Include/ {print $2}' /etc/ssh/sshd_config |
/usr/bin/tr -d '*')

if [[ -z $include_dir ]]; then
    /usr/bin/sed -i.bk "1s/.*/Include \/etc\/ssh\/sshd_config.d\/\*/"
    /etc/ssh/sshd_config
fi

/usr/bin/grep -qxF 'channeltimeout session:*=900' "${include_dir}01-mscp-
sshd.conf" 2>/dev/null || echo "channeltimeout session:*=900" >> "${include_dir}
01-mscp-sshd.conf"

for file in $(ls ${include_dir}); do
    if [[ "$file" == "100-macos.conf" ]]; then
        continue
    fi
    if [[ "$file" == "01-mscp-sshd.conf" ]]; then
        break
    fi
    /bin/mv ${include_dir}${file} ${include_dir}20-${file}
done
```

ID	os_sshd_channel_timeout_configure	
References	800-53r5	- AC-12 - SC-10
	CCE	CCE-95307-5

8.49. Configure SSHD ClientAliveCountMax to 0

If SSHD is enabled it *MUST* be configured with the Client Alive Maximum Count set to 0.

This will set the number of client alive messages which may be sent without the SSH server receiving any messages back from the client. If this threshold is reached while client alive messages are being sent, the SSH server will disconnect the client, terminating the session. The client alive

messages are sent through the encrypted channel and therefore will not be spoofable. The client alive mechanism is valuable when the client or server depend on knowing when a connection has become unresponsive.



This setting is not intended to manage idle user sessions where there is no input from the client. Its purpose is to monitor for interruptions in network connectivity and force the session to terminate after the connection appears to be broken.



On macOS 15.2 and higher the SSH configuration can be reset to the macOS default by running `/usr/libexec/reset-ssh-configuration`.

To check the state of the system, run the following command(s):

```
/usr/sbin/sshd -G | /usr/bin/awk '/clientalivecountmax/{print $2}'
```

If the result is not **0**, this is a finding.

Remediation Description

Perform the following to configure the system to meet the requirements:

```
include_dir=$(/usr/bin/awk '/^Include/ {print $2}' /etc/ssh/sshd_config |
/usr/bin/tr -d ' ')

if [[ -z $include_dir ]]; then
    /usr/bin/sed -i.bk "1s/.*/Include \/etc\/ssh\/sshd_config.d\/\*/"
    /etc/ssh/sshd_config
fi

/usr/bin/grep -qxF 'clientalivecountmax 0' "${include_dir}01-mscp-sshd.conf"
2>/dev/null || echo "clientalivecountmax 0" >> "${include_dir}01-mscp-sshd.conf"

for file in $(ls ${include_dir}); do
    if [[ "$file" == "100-macos.conf" ]]; then
        continue
    fi
    if [[ "$file" == "01-mscp-sshd.conf" ]]; then
        break
    fi
    /bin/mv ${include_dir}${file} ${include_dir}20-${file}
done
```

ID

os_sshd_client_alive_count_max_configure

References	800-53r5	• SC-10
	CCE	• CCE-95308-3

8.50. Configure SSHD ClientAliveInterval to 900

If SSHD is enabled then it *MUST* be configured with the Client Alive Interval set to 900.

Sets a timeout interval in seconds after which if no data has been received from the client, sshd(8) will send a message through the encrypted channel to request a response from the client.

This setting works in conjunction with ClientAliveCountMax to determine the termination of the connection after the threshold has been reached.



This setting is not intended to manage idle user sessions where there is no input from the client. Its purpose is to monitor for interruptions in network connectivity and force the session to terminate after the connection appears to be broken.



On macOS 15.2 and higher the SSH configuration can be reset to the macOS default by running `/usr/libexec/reset-ssh-configuration`.

To check the state of the system, run the following command(s):

```
/usr/sbin/sshd -G | /usr/bin/awk '/clientaliveinterval/{print $2}'
```

If the result is not **900**, this is a finding.

Remediation Description

Perform the following to configure the system to meet the requirements:

```
include_dir=$(/usr/bin/awk '/^Include/ {print $2}' /etc/ssh/sshd_config |
/usr/bin/tr -d ' ')

if [[ -z $include_dir ]]; then
    /usr/bin/sed -i.bk "1s/.*/Include \/etc\/ssh\/sshd_config.d\/\*/"
    /etc/ssh/sshd_config
fi

/usr/bin/grep -qxF 'clientaliveinterval 900' "${include_dir}01-mscp-sshd.conf"
2>/dev/null || echo "clientaliveinterval 900" >> "${include_dir}01-mscp-sshd.conf"

for file in $(ls $include_dir); do
    if [[ "$file" == "100-macos.conf" ]]; then
        continue
    fi
    if [[ "$file" == "01-mscp-sshd.conf" ]]; then
```

```

        break
    fi
    /bin/mv ${include_dir}${file} ${include_dir}20-${file}
done

```

ID	os_sshd_client_alive_interval_configure	
References	800-53r5	• AC-12 • SC-10
	CCE	• CCE-95309-1

8.51. Limit SSHD to FIPS Compliant Connections

If SSHD is enabled then it *MUST* be configured to limit the Ciphers, HostbasedAcceptedAlgorithms, HostKeyAlgorithms, KexAlgorithms, MACs, PubkeyAcceptedAlgorithms, CASignatureAlgorithms to algorithms that are FIPS 140 validated.

FIPS 140-3 is the current standard for validating that mechanisms used to access cryptographic modules utilize authentication that meet federal requirements.

Operating systems utilizing encryption *MUST* use FIPS validated mechanisms for authenticating to cryptographic modules.



For more information on FIPS compliance with the version of SSHD included in the macOS, the manual page `apple_ssh_and_fips` has additional information.



On macOS 15.2 and higher the SSH configuration can be reset to the macOS default by running `/usr/libexec/reset-ssh-configuration`.

To check the state of the system, run the following command(s):

```

fips_sshd_config=("Ciphers aes128-gcm@openssh.com" "HostbasedAcceptedAlgorithms ecdsa-
sha2-nistp256,ecdsa-sha2-nistp256-cert-v01@openssh.com" "HostKeyAlgorithms ecdsa-sha2-
nistp256-cert-v01@openssh.com,sk-ecdsa-sha2-nistp256-cert-v01@openssh.com,ecdsa-sha2-
nistp256,sk-ecdsa-sha2-nistp256@openssh.com" "KexAlgorithms ecdh-sha2-nistp256" "MACs
hmac-sha2-256-etm@openssh.com,hmac-sha2-256" "PubkeyAcceptedAlgorithms ecdsa-sha2-
nistp256,ecdsa-sha2-nistp256-cert-v01@openssh.com,sk-ecdsa-sha2-nistp256-cert-
v01@openssh.com" "CASignatureAlgorithms ecdsa-sha2-nistp256,sk-ecdsa-sha2-
nistp256@openssh.com")
total=0
for config in $fips_sshd_config; do
    total=$((expr $(/usr/sbin/sshd -G | /usr/bin/grep -i -c "$config") + $total))
done

echo $total

```

If the result is not 7, this is a finding.

Remediation Description

Perform the following to configure the system to meet the requirements:

```
if [ -f /etc/ssh/crypto.conf ] && /usr/bin/grep -q "Include /etc/ssh/crypto.conf"
/etc/ssh/sshd_config.d/100-macos.conf 2>/dev/null; then
    /bin/ln -fs /etc/ssh/crypto/fips.conf /etc/ssh/crypto.conf
fi

include_dir=$(/usr/bin/awk '/^Include/ {print $2}' /etc/ssh/sshd_config |
/usr/bin/tr -d '*')

if [[ -z $include_dir ]]; then
    /usr/bin/sed -i.bk "1s/.*/Include \/etc\/ssh\/sshd_config.d\/\*/"
/etc/ssh/sshd_config
fi

fips_sshd_config=("Ciphers aes128-gcm@openssh.com" "HostbasedAcceptedAlgorithms
ecdsa-sha2-nistp256,ecdsa-sha2-nistp256-cert-v01@openssh.com" "HostKeyAlgorithms
ecdsa-sha2-nistp256-cert-v01@openssh.com,sk-ecdsa-sha2-nistp256-cert-
v01@openssh.com,ecdsa-sha2-nistp256,sk-ecdsa-sha2-nistp256@openssh.com"
"KexAlgorithms ecdh-sha2-nistp256" "MACs hmac-sha2-256-etm@openssh.com,hmac-sha2-
256" "PubkeyAcceptedAlgorithms ecdsa-sha2-nistp256,ecdsa-sha2-nistp256-cert-
v01@openssh.com,sk-ecdsa-sha2-nistp256-cert-v01@openssh.com"
"CASignatureAlgorithms ecdsa-sha2-nistp256,sk-ecdsa-sha2-nistp256@openssh.com")
sshd_config=$(/usr/sbin/sshd -G)
for config in $fips_sshd_config; do
    if ! echo $sshd_config | /usr/bin/grep -q -i "$config" 2>/dev/null; then
        /usr/bin/grep -qxF "$config" "${include_dir}01-mSCP-sshd.conf" 2>/dev/null ||
echo "$config" >> "${include_dir}01-mSCP-sshd.conf"
    fi
done

for file in $(ls ${include_dir}); do
    if [[ "$file" == "100-macos.conf" ]]; then
        continue
    fi
    if [[ "$file" == "01-mSCP-sshd.conf" ]]; then
        break
    fi
    /bin/mv ${include_dir}${file} ${include_dir}20-${file}
done
```

ID	os_sshd_fips_compliant
----	------------------------

References	800-53r5	• AC-17(2) • IA-7 • SC-13 • SC-8(1)
	CCE	• CCE-95310-9

8.52. Configure SSHD Unused Connection Timeout to 900

If SSHD is enabled it *MUST* be configured with unused connection timeout set to 900.

This will set the time out when there are no open channels within an session.



On macOS 15.2 and higher the SSH configuration can be reset to the macOS default by running `/usr/libexec/reset-ssh-configuration`.

To check the state of the system, run the following command(s):

```
/usr/sbin/sshd -G | /usr/bin/awk '/unusedconnectiontimeout/{print $2}'
```

If the result is not **900**, this is a finding.

Remediation Description

Perform the following to configure the system to meet the requirements:

```
include_dir=$(/usr/bin/awk '/^Include/ {print $2}' /etc/ssh/sshd_config |
/usr/bin/tr -d '*')

if [[ -z $include_dir ]]; then
    /usr/bin/sed -i.bk "1s/.*/Include \/etc\/ssh\/sshd_config.d\/\*/"
    /etc/ssh/sshd_config
fi

/usr/bin/grep -qxF 'unusedconnectiontimeout 900' "${include_dir}01-mSCP-sshd.conf"
2>/dev/null || echo "unusedconnectiontimeout 900" >> "${include_dir}01-mSCP-
sshd.conf"

for file in $(ls ${include_dir}); do
    if [[ "$file" == "100-macos.conf" ]]; then
        continue
    fi
    if [[ "$file" == "01-mSCP-sshd.conf" ]]; then
        break
    fi
done
```

```
fi
/bin/mv ${include_dir}${file} ${include_dir}20-${file}
done
```

ID	os_sshd_unused_connection_timeout_configure	
References	800-53r5	• AC-12 • SC-10
	CCE	• CCE-95314-1

8.53. Configure Sudo To Log Events

Sudo *MUST* be configured to log privilege escalation.

To check the state of the system, run the following command(s):

```
/usr/bin/sudo /usr/bin/sudo -V | /usr/bin/grep -c "Log when a command is allowed by sudoers"
```

If the result is not 1, this is a finding.

Remediation Description

Perform the following to configure the system to meet the requirements:

```
/usr/bin/find /etc/sudoers* -type f -exec sed -i ''
'^Defaults[[:blank:]]*\\!log_allowed/s/^/# /' '{}' \;
/bin/echo "Defaults log_allowed" >> /etc/sudoers.d/mscp
```

ID	os_sudo_log_enforce	
References	800-53r5	• AC-6(9)
	CCE	• CCE-95316-6

8.54. Configure Sudoers Timestamp Type

The file `/etc/sudoers` *MUST* be configured to not include a `timestamp_type` of `global` or `ppid` and be configured for timestamp record types of `tty`.

This rule ensures that the "sudo" command will prompt for the administrator's password at least once in each newly opened terminal window. This prevents a malicious user from taking advantage of an unlocked computer or an abandoned logon session by bypassing the normal password

prompt requirement.

To check the state of the system, run the following command(s):

```
/usr/bin/sudo /usr/bin/sudo -V | /usr/bin/awk -F": " ' /Type of authentication
timestamp record/{print $2}'
```

If the result is not **tty**, this is a finding.

Remediation Description

Perform the following to configure the system to meet the requirements:

```
/usr/bin/find /etc/sudoers* -type f -exec sed -i '' '/timestamp_type/d;
/!tty_tickets/d' '{}' \;
```

ID	os_sudoers_timestamp_type_configure	
References	800-53r5	• CM-5(1) • IA-11
	CCE	• CCE-95318-2

8.55. Disable Trivial File Transfer Protocol Service

If the system does not require Trivial File Transfer Protocol (TFTP), support it is non-essential and *MUST* be disabled.

The information system *MUST* be configured to provide only essential capabilities. Disabling TFTP helps prevent the unauthorized connection of devices and the unauthorized transfer of information.



TFTP service is disabled at startup by default macOS.

To check the state of the system, run the following command(s):

```
result="FAIL"
enabled=$(/bin/launchctl print-disabled system | /usr/bin/grep '"com.apple.tftpd" =>
enabled')
running=$(/bin/launchctl print system/com.apple.tftpd 2>/dev/null)

if [[ -z "$running" ]] && [[ -z "$enabled" ]]; then
    result="PASS"
elif [[ -n "$running" ]]; then
    result=result+" RUNNING"
```



```
elif [[ -n "$enabled" ]]; then
    result=result+" ENABLED"
fi
echo $result
```

If the result is not **PASS**, this is a finding.

Remediation Description

Perform the following to configure the system to meet the requirements:

```
/bin/launchctl bootout system/com.apple.tftpd
/bin/launchctl disable system/com.apple.tftpd
```

The system may need to be restarted for the update to take effect.

ID	os_tftpd_disable	
References	800-53r5	• AC-17 • AC-3 • IA-5(1)
	CCE	• CCE-95323-2

8.56. Enable Time Synchronization Daemon

The macOS time synchronization daemon (timed) *MUST* be enabled for proper time synchronization to an authorized time server.



The time synchronization daemon is enabled by default on macOS.

To check the state of the system, run the following command(s):

```
/bin/launchctl print system | /usr/bin/grep -c -E '\tcom.apple.timed'
```

If the result is not **1**, this is a finding.

Remediation Description

Perform the following to configure the system to meet the requirements:

```
/bin/launchctl load -w /System/Library/LaunchDaemons/com.apple.timed.plist
```



The service **timed** cannot be unloaded or loaded while System Integrity Protection (SIP) is enabled.

ID	os_time_server_enabled	
References	800-53r5	• AU-12(1) • SC-45(1)
	CCE	• CCE-95325-7

8.57. Disable TouchID Prompt during Setup Assistant

The prompt for TouchID during Setup Assistant *MUST* be disabled.

macOS prompts new users through enabling TouchID during Setup Assistant; this is not essential and, therefore, *MUST* be disabled to prevent against the risk of individuals electing to enable TouchID to override organization-wide settings.

To check the state of the system, run the following command(s):

```
/usr/bin/osascript -l JavaScript 2>/dev/null << EOS
$.NSUserDefaults.alloc.initWithSuiteName('com.apple.SetupAssistant.managed')\
.objectForKey('SkipSetupItems').containsObject("Biometric")
EOS
```

If the result is not **true**, this is a finding.

Remediation Description

Perform the following to configure the system to meet the requirements:

Create a configuration profile containing the following keys in the (com.apple.SetupAssistant.managed) payload type:

```
<key>SkipSetupItems</key>
<array>
  <string>Biometric</string>
</array>
```

ID	os_touchid_prompt_disable	
References	800-53r5	• CM-6
	CCE	• CCE-95326-5

8.58. Disable Login to Other User's Active and Locked Sessions

The ability to log in to another user's active or locked session *MUST* be disabled.

macOS has a privilege that can be granted to any user that will allow that user to unlock active user's sessions. Disabling the admins and/or user's ability to log into another user's active and locked session prevents unauthorized persons from viewing potentially sensitive and/or personal information.



Configuring this setting will change the user experience and disable TouchID from unlocking the screensaver. A configuration profile will be generated to include the setting that restores the expected behavior. You can also apply the settings using `/usr/bin/sudo /usr/bin/defaults write /Library/Preferences/com.apple.loginwindow screenUnlockMode -int 1`.



Do not apply this rule if your organization uses smartcards and Platform Single Sign-On (PSSO).

To check the state of the system, run the following command(s):

```
RESULT="FAIL"
SS_RULE=$(/usr/bin/security -q authorizationdb read system.login.screensaver 2>&1 |
/usr/bin/xmllint --xpath "//dict/key[.='rule']/following-sibling::array[1]/string/text()" -)

if [[ "${SS_RULE}" == "authenticate-session-owner" ]]; then
    RESULT="PASS"
else
    PSSO_CHECK=$(/usr/bin/security -q authorizationdb read "$SS_RULE" 2>&1 |
/usr/bin/xmllint --xpath '//key[.="rule"]/following-sibling::array[1]/string/text()' -)
    if /usr/bin/grep -Fxq "authenticate-session-owner" <<<"$PSSO_CHECK"; then
        RESULT="PASS"
    fi
fi

echo $RESULT
```

If the result is not **PASS**, this is a finding.

Remediation Description

Perform the following to configure the system to meet the requirements:

Create a configuration profile containing the following keys in the (com.apple.loginwindow) payload type:

```
<key>screenUnlockMode</key>
<integer>1</integer>
```

ID	os_unlock_active_user_session_disable	
References	800-53r5	• IA-2, IA-2(5)
	CCE	• CCE-95328-1

8.59. Disable Unix-to-Unix Copy Protocol Service

The system *MUST* not have the Unix-to-Unix Copy Protocol (UUCP) service active.

UUCP, a set of programs that enable the sending of files between different UNIX systems as well as sending commands to be executed on another system, is not essential and *MUST* be disabled in order to prevent the unauthorized connection of devices, transfer of information, and tunneling.



UUCP service is disabled at startup by default macOS.

To check the state of the system, run the following command(s):

```
result="FAIL"
enabled=$(/bin/launchctl print-disabled system | /usr/bin/grep '"com.apple.uucp" =>
enabled')
running=$(/bin/launchctl print system/com.apple.uucp 2>/dev/null)

if [[ -z "$running" ]] && [[ -z "$enabled" ]]; then
    result="PASS"
elif [[ -n "$running" ]]; then
    result=result+" RUNNING"
elif [[ -n "$enabled" ]]; then
    result=result+" ENABLED"
fi
echo $result
```

If the result is not **PASS**, this is a finding.

Remediation Description

Perform the following to configure the system to meet the requirements:

```
/bin/launchctl bootout system/com.apple.uucp
/bin/launchctl disable system/com.apple.uucp
```

The system may need to be restarted for the update to take effect.

ID	os_uucp_disable	
References	800-53r5	• AC-17 • AC-3
	CCE	• CCE-95330-7

8.60. Disable Apple Intelligence Writing Tools

Apple Intelligence features such as writing tools that use off device AI *MUST* be disabled.

To check the state of the system, run the following command(s):

```
/usr/bin/osascript -l JavaScript << EOS
$.NSUserDefaults.alloc.initWithSuiteName('com.apple.applicationaccess')\
.objectForKey('allowWritingTools').js
EOS
```

If the result is not **false**, this is a finding.

Remediation Description

Perform the following to configure the system to meet the requirements:

Create a configuration profile containing the following keys in the (com.apple.applicationaccess) payload type:

```
<key>allowWritingTools</key>
<false/>
```

ID	os_writing_tools_disable	
References	800-53r5	• AC-20, AC-20(1) • CM-7, CM-7(1) • SC-7(10)
	CCE	• CCE-95334-9

8.61. Disable AppleID and Internet Account Modifications

The system *MUST* disable account modification.

Account modification includes adding additional or modifying internet accounts in Apple Mail, Calendar, Contacts, in the Internet Account System Setting Pane, or the AppleID System Setting Pane.

This prevents the addition of unauthorized accounts.



Some organizations may allow the use and configuration of the built-in Mail.app, Calendar.app, and Contacts.app for organizational communication. Information System Security Officers (ISSOs) may make the risk-based decision not to disable the Internet Accounts System Preference pane to avoid losing this functionality, but they are advised to first fully weigh the potential risks posed to their organization.

To check the state of the system, run the following command(s):

```
/usr/bin/osascript -l JavaScript << EOS
$.NSUserDefaults.alloc.initWithSuiteName('com.apple.applicationaccess')\
.objectForKey('allowAccountModification').js
EOS
```

If the result is not **false**, this is a finding.

Remediation Description

Perform the following to configure the system to meet the requirements:

Create a configuration profile containing the following keys in the (com.apple.applicationaccess) payload type:

```
<key>allowAccountModification</key>
<false/>
```

ID	os_account_modification_disable	
References	800-53r5	- AC-20, AC-20(1) - CM-7, CM-7(1)
	CCE	CCE-95155-8

Chapter 9. System Settings

This section contains the configuration and enforcement of the settings within the macOS System Settings application.



The check/fix commands outlined in this section *MUST* be run by a user with elevated privileges.

9.1. Prevent Apple Watch from Terminating a Session Lock

Apple Watches are not an approved authenticator and their use *MUST* be disabled.

Disabling Apple watches is a necessary step to ensuring that the information system retains a session lock until the user reestablishes access using an authorized identification and authentication procedures.



Unlocking the system with an Apple Watch is not an approved authenticator for US Federal Government usage as it has not been verified to meet the strength requirements outlined in NIST SP 800-63.

To check the state of the system, run the following command(s):

```
/usr/bin/osascript -l JavaScript << EOS
$.NSUserDefaults.alloc.initWithSuiteName('com.apple.applicationaccess')\
.objectForKey('allowAutoUnlock').js
EOS
```

If the result is not **false**, this is a finding.

Remediation Description

Perform the following to configure the system to meet the requirements:

Create a configuration profile containing the following keys in the (com.apple.applicationaccess) payload type:

```
<key>allowAutoUnlock</key>
<false/>
```

ID	system_settings_apple_watch_unlock_disable
----	--

References	800-53r5	• IA-5
	CCE	• CCE-95355-4

9.2. Disable Unattended or Automatic Logon to the System

Automatic logon *MUST* be disabled.

When automatic logons are enabled, the default user account is automatically logged on at boot time without prompting the user for a password. Even if the screen is later locked, a malicious user would be able to reboot the computer and find it already logged in. Disabling automatic logons mitigates this risk.

To check the state of the system, run the following command(s):

```
/usr/bin/osascript -l JavaScript << EOS
$.NSUserDefaults.alloc.initWithSuiteName('com.apple.loginwindow')\
.objectForKey('com.apple.login.mcx.DisableAutoLoginClient').js
EOS
```

If the result is not **true**, this is a finding.

Remediation Description

Perform the following to configure the system to meet the requirements:

Create a configuration profile containing the following keys in the (com.apple.loginwindow) payload type:

```
<key>com.apple.login.mcx.DisableAutoLoginClient</key>
<true/>
```

ID	system_settings_automatic_login_disable	
References	800-53r5	• IA-2 • IA-5(13)
	CCE	• CCE-95356-2

9.3. Enforce Auto Logout After 86400 Seconds of Inactivity

Auto logout *MUST* be configured to automatically terminate a user session and log out the after

86400 seconds of inactivity.

NOTE:The maximum that macOS can be configured for autologoff is 86400 seconds.



The automatic logout may cause disruptions to an organization’s workflow and/or loss of data. Information System Security Officers (ISSOs) are advised to first fully weigh the potential risks posed to their organization before opting to disable the automatic logout setting.

To check the state of the system, run the following command(s):

```
/usr/bin/osascript -l JavaScript << EOS
$.NSUserDefaults.alloc.initWithSuiteName('.GlobalPreferences')\
.objectForKey('com.apple.autologout.AutoLogOutDelay').js
EOS
```

If the result is not **86400**, this is a finding.

Remediation Description

Perform the following to configure the system to meet the requirements:

Create a configuration profile containing the following keys in the (.GlobalPreferences) payload type:

```
<key>com.apple.autologout.AutoLogOutDelay</key>
<integer>86400</integer>
```

ID	system_settings_automatic_logout_enforce	
References	800-53r5	• AC-12 • AC-2(5)
	CCE	• CCE-95357-0

9.4. Disable Bluetooth When no Approved Device is Connected

The macOS system *MUST* be configured to disable Bluetooth unless there is an approved device connected.



Information System Security Officers (ISSOs) may make the risk-based decision not to disable Bluetooth, so as to maintain necessary functionality, but they are advised to first fully weigh the potential risks posed to their organization.

To check the state of the system, run the following command(s):

```
/usr/bin/osascript -l JavaScript << EOS
$.NSUserDefaults.alloc.initWithSuiteName('com.apple.MCXBluetooth')\
.objectForKey('DisableBluetooth').js
EOS
```

If the result is not **true**, this is a finding.

Remediation Description

Perform the following to configure the system to meet the requirements:



The following settings are in the (com.apple.ManagedClient.preferences) payload. This payload requires the additional settings to be sub-payloads within, containing their defined payload types.

Create a configuration profile containing the following keys in the (com.apple.MCXBluetooth) payload type:

```
<key>DisableBluetooth</key>
<true/>
```

ID	system_settings_bluetooth_disable	
References	800-53r5	• AC-18, AC-18(3) • SC-8
	CCE	• CCE-95358-8

9.5. Disable Bluetooth Sharing

Bluetooth Sharing *MUST* be disabled.

Bluetooth Sharing allows users to wirelessly transmit files between the macOS and Bluetooth-enabled devices, including personally owned cellphones and tablets. A malicious user might introduce viruses or malware onto the system or extract sensitive files via Bluetooth Sharing. When Bluetooth Sharing is disabled, this risk is mitigated.



The check and fix are for the last logged in user. To get the last logged in user, run the following.

```
CURRENT_USER=$( /usr/bin/defaults read
/Library/Preferences/com.apple.loginwindow lastUserName )
```

To check the state of the system, run the following command(s):

```
/usr/bin/sudo -u "$CURRENT_USER" /usr/bin/defaults -currentHost read
com.apple.Bluetooth PrefKeyServicesEnabled
```

If the result is not **0**, this is a finding.

Remediation Description

Perform the following to configure the system to meet the requirements:

```
/usr/bin/sudo -u "$CURRENT_USER" /usr/bin/defaults -currentHost write
com.apple.Bluetooth PrefKeyServicesEnabled -bool false
```

ID	system_settings_bluetooth_sharing_disable	
References	800-53r5	• AC-18(4) • AC-3 • CM-7, CM-7(1)
	CCE	• CCE-95361-2

9.6. Disable Content Caching Service

Content caching *MUST* be disabled.

Content caching is a macOS service that helps reduce Internet data usage and speed up software installation on Mac computers. It is not recommended for devices furnished to employees to act as a caching server.

To check the state of the system, run the following command(s):

```
/usr/bin/osascript -l JavaScript << EOS
$.NSUserDefaults.alloc.initWithSuiteName('com.apple.applicationaccess')\
.objectForKey('allowContentCaching').js
EOS
```

If the result is not **false**, this is a finding.

Remediation Description

Perform the following to configure the system to meet the requirements:

Create a configuration profile containing the following keys in the

(com.apple.applicationaccess) payload type:

```
<key>allowContentCaching</key>
<false/>
```

ID	system_settings_content_caching_disable	
References	800-53r5	• CM-7, CM-7(1)
	CCE	• CCE-95362-0

9.7. Disable Sending Diagnostic and Usage Data to Apple

The ability to submit diagnostic data to Apple *MUST* be disabled.

The information system *MUST* be configured to provide only essential capabilities. Disabling the submission of diagnostic and usage information will mitigate the risk of unwanted data being sent to Apple.

To check the state of the system, run the following command(s):

```
/usr/bin/osascript -l JavaScript << EOS
function run() {
let pref1 = $.NSUserDefaults.alloc.initWithSuiteName('com.apple.SubmitDiagInfo')\
.objectForKey('AutoSubmit').js
let pref2 = $.NSUserDefaults.alloc.initWithSuiteName('com.apple.applicationaccess')\
.objectForKey('allowDiagnosticSubmission').js
if ( pref1 == false && pref2 == false ){
    return("true")
} else {
    return("false")
}
}
EOS
```

If the result is not **true**, this is a finding.

Remediation Description

Perform the following to configure the system to meet the requirements:

Create a configuration profile containing the following keys in the (com.apple.SubmitDiagInfo) payload type:

```
<key>AutoSubmit</key>
```

```
<false/>
```

Create a configuration profile containing the following keys in the (com.apple.applicationaccess) payload type:

```
<key>allowDiagnosticSubmission</key>
<false/>
```

ID	system_settings_diagnostics_reports_disable	
References	800-53r5	• AC-20 • SC-7(10) • SI-11
	CCE	• CCE-95364-6

9.8. Disable External Intelligence Integrations

Integration with external intelligence systems *MUST* be disabled unless approved by the organization. Disabling external intelligence integration will mitigate the risk of data being sent to unapproved third party.

The information system *MUST* be configured to provide only essential capabilities.

To check the state of the system, run the following command(s):

```
/usr/bin/osascript -l JavaScript << EOS
$.NSUserDefaults.alloc.initWithSuiteName('com.apple.applicationaccess')\
.objectForKey('allowExternalIntelligenceIntegrations').js
EOS
```

If the result is not **false**, this is a finding.

Remediation Description

Perform the following to configure the system to meet the requirements:

Create a configuration profile containing the following keys in the (com.apple.applicationaccess) payload type:

```
<key>allowExternalIntelligenceIntegrations</key>
<false/>
```

ID	system_settings_external_intelligence_disable	
References	800-53r5	• AC-20 • CM-7, CM-7(1)
	CCE	• CCE-95365-3

9.9. Disable External Intelligence Integration Sign In

The ability to sign into an external intelligence systems *MUST* be disabled unless approved by the organization. Disabling external intelligence integration will mitigate the risk of data being sent to unapproved third party.

The information system *MUST* be configured to provide only essential capabilities.

To check the state of the system, run the following command(s):

```
/usr/bin/osascript -l JavaScript << EOS
$.NSUserDefaults.alloc.initWithSuiteName('com.apple.applicationaccess')\
.objectForKey('allowExternalIntelligenceIntegrationsSignIn').js
EOS
```

If the result is not **false**, this is a finding.

Remediation Description

Perform the following to configure the system to meet the requirements:

Create a configuration profile containing the following keys in the (com.apple.applicationaccess) payload type:

```
<key>allowExternalIntelligenceIntegrationsSignIn</key>
<false/>
```

ID	system_settings_external_intelligence_sign_in_disable	
References	800-53r5	• AC-20 • CM-7, CM-7(1)
	CCE	• CCE-95366-1

9.10. Enforce FileVault

FileVault *MUST* be enforced.

The information system implements cryptographic mechanisms to protect the confidentiality and

integrity of information stored on digital media during transport outside of controlled areas.



See the FileVault supplemental to implement this rule.

To check the state of the system, run the following command(s):

```
dontAllowDisable=$(/usr/bin/osascript -l JavaScript << EOS
$.NSUserDefaults.alloc.initWithSuiteName('com.apple.MCX')\
.objectForKey('dontAllowFDEDisable').js
EOS
)
fileVault=$(/usr/bin/fdesetup status | /usr/bin/grep -c "FileVault is On.")
if [[ "$dontAllowDisable" == "true" ]] && [[ "$fileVault" == 1 ]]; then
    echo "1"
else
    echo "0"
fi
```

If the result is not 1, this is a finding.

Remediation Description

Perform the following to configure the system to meet the requirements:

Create a configuration profile containing the following keys in the (com.apple.MCX) payload type:

```
<key>dontAllowFDEDisable</key>
<true/>
```

ID	system_settings_filevault_enforce	
References	800-53r5	• SC-28, SC-28(1)
	CCE	• CCE-95367-9

9.11. Disable Find My Service

The Find My service *MUST* be disabled.

A Mobile Device Management (MDM) solution *MUST* be used to carry out remote locking and wiping instead of Apple’s Find My service.

Apple’s Find My service uses a personal AppleID for authentication. Organizations should rely on MDM solutions, which have much more secure authentication requirements, to perform remote lock and remote wipe.

To check the state of the system, run the following command(s):

```
/usr/bin/osascript -l JavaScript << EOS
function run() {
  let pref1 = ObjC.unwrap(
$.NSUserDefaults.alloc.initWithSuiteName('com.apple.applicationaccess')\
.objectForKey('allowFindMyDevice'))
  let pref2 = ObjC.unwrap(
$.NSUserDefaults.alloc.initWithSuiteName('com.apple.applicationaccess')\
.objectForKey('allowFindMyFriends'))
  let pref3 = ObjC.unwrap(
$.NSUserDefaults.alloc.initWithSuiteName('com.apple.icloud.managed')\
.objectForKey('DisableFMMiCloudSetting'))
  if ( pref1 == false && pref2 == false && pref3 == true ) {
    return("true")
  } else {
    return("false")
  }
}
EOS
```

If the result is not **true**, this is a finding.

Remediation Description

Perform the following to configure the system to meet the requirements:

Create a configuration profile containing the following keys in the (com.apple.applicationaccess) payload type:

```
<key>allowFindMyDevice</key>
<false/>
<key>allowFindMyFriends</key>
<false/>
```

Create a configuration profile containing the following keys in the (com.apple.icloud.managed) payload type:

```
<key>DisableFMMiCloudSetting</key>
<true/>
```

ID	system_settings_find_my_disable
----	---------------------------------

References	800-53r5	• AC-20 • CM-7, CM-7(1)
	CCE	• CCE-95368-7

9.12. Enable macOS Application Firewall

The macOS Application Firewall is the built-in firewall that comes with macOS, and it *MUST* be enabled.

When the macOS Application Firewall is enabled, the flow of information within the information system and between interconnected systems will be controlled by approved authorizations.

To check the state of the system, run the following command(s):

```
/usr/bin/osascript -l JavaScript << EOS
$.NSUserDefaults.alloc.initWithSuiteName('com.apple.security.firewall')\
.objectForKey('EnableFirewall').js
EOS
```

If the result is not **true**, this is a finding.

Remediation Description

Perform the following to configure the system to meet the requirements:

Create a configuration profile containing the following keys in the (com.apple.security.firewall) payload type:

```
<key>EnableFirewall</key>
<true/>
```

ID	system_settings_firewall_enable	
References	800-53r5	• AC-4 • CM-7, CM-7(1) • SC-7, SC-7(12)
	CCE	• CCE-95369-5

9.13. Enable Firewall Stealth Mode

Firewall Stealth Mode *MUST* be enabled.

When stealth mode is enabled, the Mac will not respond to any probing requests, and only requests

from authorized applications will still be authorized.



Enabling firewall stealth mode may prevent certain remote mechanisms used for maintenance and compliance scanning from properly functioning. Information System Security Officers (ISSOs) are advised to first fully weigh the potential risks posed to their organization before opting not to enable stealth mode.

To check the state of the system, run the following command(s):

```
/usr/bin/osascript -l JavaScript << EOS
$.NSUserDefaults.alloc.initWithSuiteName('com.apple.security.firewall')\
.objectForKey('EnableStealthMode').js
EOS
```

If the result is not **true**, this is a finding.

Remediation Description

Perform the following to configure the system to meet the requirements:

Create a configuration profile containing the following keys in the (com.apple.security.firewall) payload type:

```
<key>EnableStealthMode</key>
<true/>
<key>EnableFirewall</key>
<true/>
```

ID	system_settings_firewall_stealth_mode_enable	
References	800-53r5	• CM-7, CM-7(1) • SC-7, SC-7(16)
	CCE	• CCE-95370-3

9.14. Apply Gatekeeper Settings to Block Applications from Unidentified Developers

The information system implements cryptographic mechanisms to authenticate software prior to installation.

Gatekeeper settings must be configured correctly to only allow the system to run applications downloaded from the Mac App Store or applications signed with a valid Apple Developer ID code. Administrator users will still have the option to override these settings on a per-app basis. Gatekeeper is a security feature that ensures that applications must be digitally signed by an Apple-

issued certificate in order to run. Digital signatures allow the macOS to verify that the application has not been modified by a malicious third party.

To check the state of the system, run the following command(s):

```
/usr/bin/osascript -l JavaScript << EOS
function run() {
  let pref1 = ObjC.unwrap(
$.NSUserDefaults.alloc.initWithSuiteName('com.apple.systempolicy.control')\
.objectForKey('AllowIdentifiedDevelopers'))
  let pref2 = ObjC.unwrap(
$.NSUserDefaults.alloc.initWithSuiteName('com.apple.systempolicy.control')\
.objectForKey('EnableAssessment'))
  if ( pref1 == true && pref2 == true ) {
    return("true")
  } else {
    return("false")
  }
}
EOS
```

If the result is not **true**, this is a finding.

Remediation Description

Perform the following to configure the system to meet the requirements:

Create a configuration profile containing the following keys in the (com.apple.systempolicy.control) payload type:

```
<key>AllowIdentifiedDevelopers</key>
<true/>
<key>EnableAssessment</key>
<true/>
```

ID	system_settings_gatekeeper_identified_developers_allowed	
References	800-53r5	• CM-14 • CM-5 • SI-7(1), SI-7(15)
	CCE	• CCE-95371-1

9.15. Configure Gatekeeper to Disallow End User Override

Gatekeeper *MUST* be configured with a configuration profile to prevent normal users from overriding its settings.

If users are allowed to disable Gatekeeper or set it to a less restrictive setting, malware could be introduced into the system.

To check the state of the system, run the following command(s):

```
/usr/bin/osascript -l JavaScript << EOS
$.NSUserDefaults.alloc.initWithSuiteName('com.apple.systempolicy.managed')\
.objectForKey('DisableOverride').js
EOS
```

If the result is not **true**, this is a finding.

Remediation Description

Perform the following to configure the system to meet the requirements:

Create a configuration profile containing the following keys in the (com.apple.systempolicy.managed) payload type:

```
<key>DisableOverride</key>
<true/>
```

ID	system_settings_gatekeeper_override_disallow	
References	800-53r5	• CM-5 • SI-7(15)
	CCE	• CCE-95372-9

9.16. Disable Guest Access to Shared SMB Folders

Guest access to shared Server Message Block (SMB) folders *MUST* be disabled.

Turning off guest access prevents anonymous users from accessing files shared via SMB.

To check the state of the system, run the following command(s):

```
/usr/bin/defaults read /Library/Preferences/SystemConfiguration/com.apple.smb.server
```

If the result is not **0**, this is a finding.

Remediation Description

Perform the following to configure the system to meet the requirements:

```
/usr/sbin/sysadminctl -smbGuestAccess off
```

ID	system_settings_guest_access_smb_disable	
References	800-53r5	• AC-2, AC-2(9)
	CCE	• CCE-95373-7

9.17. Disable the Guest Account

Guest access *MUST* be disabled.

Turning off guest access prevents anonymous users from accessing files.

To check the state of the system, run the following command(s):

```
/usr/bin/osascript -l JavaScript << EOS
function run() {
    let pref1 = ObjC.unwrap($.NSUserDefaults.alloc.initWithSuiteName('com.apple.MCX')\
.objectForKey('DisableGuestAccount'))
    let pref2 = ObjC.unwrap($.NSUserDefaults.alloc.initWithSuiteName('com.apple.MCX')\
.objectForKey('EnableGuestAccount'))
    if ( pref1 == true && pref2 == false ) {
        return("true")
    } else {
        return("false")
    }
}
EOS
```

If the result is not **true**, this is a finding.

Remediation Description

Perform the following to configure the system to meet the requirements:

Create a configuration profile containing the following keys in the (com.apple.MCX) payload type:

```
<key>DisableGuestAccount</key>
<true/>
<key>EnableGuestAccount</key>
<false/>
```

ID	system_settings_guest_account_disable	
References	800-53r5	• AC-2, AC-2(9)
	CCE	• CCE-95374-5

9.18. Disable Hot Corners

Hot corners *MUST* be disabled.

The information system conceals, via the session lock, information previously visible on the display with a publicly viewable image. Although hot corners can be used to initiate a session lock or to launch useful applications, they can also be configured to disable an automatic session lock from initiating. Such a configuration introduces the risk that a user might forget to manually lock the screen before stepping away from the computer.

To check the state of the system, run the following command(s):

```
/usr/bin/profiles -P -o stdout | /usr/bin/grep -Ec '"wvous-bl-corner" = 0|"wvous-br-corner" = 0|"wvous-tl-corner" = 0|"wvous-tr-corner" = 0'
```

If the result is not 4, this is a finding.

Remediation Description

Perform the following to configure the system to meet the requirements:



The following settings are in the (com.apple.ManagedClient.preferences) payload. This payload requires the additional settings to be sub-payloads within, containing their defined payload types.

Create a configuration profile containing the following keys in the (com.apple.dock) payload type:

```
<key>wvous-bl-corner</key>
<integer>0</integer>
<key>wvous-br-corner</key>
<integer>0</integer>
<key>wvous-tr-corner</key>
<integer>0</integer>
<key>wvous-tl-corner</key>
```

```
<integer>0</integer>
```

ID	system_settings_hot_corners_disable	
References	800-53r5	• AC-11(1)
	CCE	• CCE-95375-2

9.19. Disable Sending Audio Recordings and Transcripts to Apple

The ability for Apple to store and review audio of your audio recordings and transcripts of your vocal shortcuts and voice control interactions *MUST* be disabled. This will disable "Improve Assistive Voice Features" in Privacy & Security within System Settings.

The information system *MUST* be configured to provide only essential capabilities. Disabling the submission of this information will mitigate the risk of unwanted data being sent to Apple.

To check the state of the system, run the following command(s):

```
/usr/bin/osascript -l JavaScript << EOS
$.NSUserDefaults.alloc.initWithSuiteName('com.apple.Accessibility')\
.objectForKey('AXSAudioDonationSiriImprovementEnabled').js
EOS
```

If the result is not **false**, this is a finding.

Remediation Description

Perform the following to configure the system to meet the requirements:

Create a configuration profile containing the following keys in the (com.apple.Accessibility) payload type:

```
<key>AXSAudioDonationSiriImprovementEnabled</key>
<false/>
```

ID	system_settings_improve_assistive_voice_disable	
References	800-53r5	• AC-20 • CM-7, CM-7(1) • SC-7(10)
	CCE	• CCE-95377-8

9.20. Disable Improve Search Information to Apple

Sending data to Apple to help improve search *MUST* be disabled. This will disable "Improve Search" within Spotlight in System Settings.

The information system *MUST* be configured to provide only essential capabilities. Disabling the submission of search data will mitigate the risk of unwanted data being sent to Apple.

To check the state of the system, run the following command(s):

```
/usr/bin/osascript -l JavaScript << EOS
$.NSUserDefaults.alloc.initWithSuiteName('com.apple.assistant.support')\
.objectForKey('Search Queries Data Sharing Status').js
EOS
```

If the result is not 2, this is a finding.

Remediation Description

Perform the following to configure the system to meet the requirements:

Create a configuration profile containing the following keys in the (com.apple.assistant.support) payload type:

```
<key>Search Queries Data Sharing Status</key>
<integer>2</integer>
```

ID	system_settings_improve_search_disable	
References	800-53r5	• AC-20 • CM-7, CM-7(1) • SC-7(10)
	CCE	• CCE-95378-6

9.21. Disable Improve Siri and Dictation Information to Apple

The ability for Apple to store and review audio of your Siri and Dictation interactions *MUST* be disabled.

The information system *MUST* be configured to provide only essential capabilities. Disabling the submission of Siri and Dictation information will mitigate the risk of unwanted data being sent to Apple.

To check the state of the system, run the following command(s):

```
/usr/bin/osascript -l JavaScript << EOS
$.NSUserDefaults.alloc.initWithSuiteName('com.apple.assistant.support')\
.objectForKey('Siri Data Sharing Opt-In Status').js
EOS
```

If the result is not 2, this is a finding.

Remediation Description

Perform the following to configure the system to meet the requirements:

Create a configuration profile containing the following keys in the (com.apple.assistant.support) payload type:

```
<key>Siri Data Sharing Opt-In Status</key>
<integer>2</integer>
```

ID	system_settings_improve_siri_dictation_disable	
References	800-53r5	• AC-20 • CM-7, CM-7(1) • SC-7(10)
	CCE	• CCE-95379-4

9.22. Disable the Internet Accounts System Preference Pane

The Internet Accounts System Setting *MUST* be disabled to prevent the addition of unauthorized internet accounts.



Some organizations may allow the use and configuration of the built-in Mail.app, Calendar.app, and Contacts.app for organizational communication. Information System Security Officers (ISSOs) may make the risk-based decision not to disable the Internet Accounts System Preference pane to avoid losing this functionality, but they are advised to first fully weigh the potential risks posed to their organization.

To check the state of the system, run the following command(s):

```
/usr/bin/profiles show -output stdout-xml | /usr/bin/xmllint --xpath
'//key[text()="DisabledSystemSettings"]/following-sibling::*[1]' - | /usr/bin/grep -c
```

```
com.apple.Internet-Accounts-Settings.extension
```

If the result is not **1**, this is a finding.

Remediation Description

Perform the following to configure the system to meet the requirements:

Create a configuration profile containing the following keys in the (com.apple.systempreferences) payload type:

```
<key>DisabledSystemSettings</key>
<array>
  <string>com.apple.Internet-Accounts-Settings.extension</string>
</array>
```

ID	system_settings_internet_accounts_disable	
References	800-53r5	• AC-20 • CM-7, CM-7(1), CM-7(5)
	CCE	• CCE-95381-0

9.23. Disable Internet Sharing

If the system does not require Internet sharing, support for it is non-essential and *MUST* be disabled.

The information system *MUST* be configured to provide only essential capabilities. Disabling Internet sharing helps prevent the unauthorized connection of devices, unauthorized transfer of information, and unauthorized tunneling.

To check the state of the system, run the following command(s):

```
/usr/bin/osascript -l JavaScript << EOS
$.NSUserDefaults.alloc.initWithSuiteName('com.apple.MCX')\
.objectForKey('forceInternetSharingOff').js
EOS
```

If the result is not **true**, this is a finding.

Remediation Description

Perform the following to configure the system to meet the requirements:

Create a configuration profile containing the following keys in the (com.apple.MCX) payload type:

```
<key>forceInternetSharingOff</key>
<true/>
```

ID	system_settings_internet_sharing_disable	
References	800-53r5	• AC-20 • AC-4
	CCE	• CCE-95382-8

9.24. Disable Location Services

Location Services *MUST* be disabled.

The information system *MUST* be configured to provide only essential capabilities. Disabling Location Services helps prevent the unauthorized connection of devices, unauthorized transfer of information, and unauthorized tunneling.

To check the state of the system, run the following command(s):

```
/usr/bin/sudo -u _locationd /usr/bin/osascript -l JavaScript << EOS
$.NSUserDefaults.alloc.initWithSuiteName('com.apple.locationd')\
.objectForKey('LocationServicesEnabled').js
EOS
```

If the result is not **false**, this is a finding.

Remediation Description

Perform the following to configure the system to meet the requirements:

```
/usr/bin/defaults write
/var/db/locationd/Library/Preferences/ByHost/com.apple.locationd
LocationServicesEnabled -bool false;
pid=$(/bin/launchctl print system | /usr/bin/awk '/\tcom.apple.locationd/ {print
$1}')
kill -9 $pid
```

ID	system_settings_location_services_disable
----	---

References	800-53r5	• CM-7, CM-7(1) • SC-7(10)
	CCE	• CCE-95383-6

9.25. Configure Login Window to Prompt for Username and Password

The login window *MUST* be configured to prompt all users for both a username and a password.

By default, the system displays a list of known users on the login window, which can make it easier for a malicious user to gain access to someone else's account. Requiring users to type in both their username and password mitigates the risk of unauthorized users gaining access to the information system.

To check the state of the system, run the following command(s):

```
/usr/bin/osascript -l JavaScript << EOS
$.NSUserDefaults.alloc.initWithSuiteName('com.apple.loginwindow')\
.objectForKey('SHOWFULLNAME').js
EOS
```

If the result is not **true**, this is a finding.

Remediation Description

Perform the following to configure the system to meet the requirements:

Create a configuration profile containing the following keys in the (com.apple.loginwindow) payload type:

```
<key>SHOWFULLNAME</key>
<true/>
```

ID	system_settings_loginwindow_prompt_username_password_enforce	
References	800-53r5	• IA-2
	CCE	• CCE-95387-7

9.26. Disable Media Sharing

Media sharing *MUST* be disabled.

When Media Sharing is enabled, the computer starts a network listening service that shares the

contents of the user’s music collection with other users in the same subnet.

The information system *MUST* be configured to provide only essential capabilities. Disabling Media Sharing helps prevent the unauthorized connection of devices and the unauthorized transfer of information. Disabling Media Sharing mitigates this risk.

To check the state of the system, run the following command(s):

```
/usr/bin/osascript -l JavaScript << EOS
function run() {
  let pref1 = ObjC.unwrap(
$.NSUserDefaults.alloc.initWithSuiteName('com.apple.applicationaccess')\
.objectForKey('allowMediaSharing'))
  let pref2 = ObjC.unwrap(
$.NSUserDefaults.alloc.initWithSuiteName('com.apple.applicationaccess')\
.objectForKey('allowMediaSharingModification'))
  if ( pref1 == false && pref2 == false ) {
    return("true")
  } else {
    return("false")
  }
}
EOS
```

If the result is not **true**, this is a finding.

Remediation Description

Perform the following to configure the system to meet the requirements:

Create a configuration profile containing the following keys in the (com.apple.applicationaccess) payload type:

```
<key>allowMediaSharing</key>
<false/>
<key>allowMediaSharingModification</key>
<false/>
```

ID	system_settings_media_sharing_disabled	
References	800-53r5	• AC-17 • AC-3
	CCE	• CCE-95388-5

9.27. Disable Password Hints

Password hints *MUST* be disabled.

Password hints leak information about passwords that are currently in use and can lead to loss of confidentiality.

To check the state of the system, run the following command(s):

```
/usr/bin/osascript -l JavaScript << EOS
$.NSUserDefaults.alloc.initWithSuiteName('com.apple.loginwindow')\
.objectForKey('RetriesUntilHint').js
EOS
```

If the result is not 0, this is a finding.

Remediation Description

Perform the following to configure the system to meet the requirements:

Create a configuration profile containing the following keys in the (com.apple.loginwindow) payload type:

```
<key>RetriesUntilHint</key>
<integer>0</integer>
```

ID	system_settings_password_hints_disable	
References	800-53r5	• IA-6
	CCE	• CCE-95389-3

9.28. Disable Personalized Advertising

Ad tracking and targeted ads *MUST* be disabled.

The information system *MUST* be configured to provide only essential capabilities. Disabling ad tracking ensures that applications and advertisers are unable to track users' interests and deliver targeted advertisements.

To check the state of the system, run the following command(s):

```
/usr/bin/osascript -l JavaScript << EOS
$.NSUserDefaults.alloc.initWithSuiteName('com.apple.applicationaccess')\
.objectForKey('allowApplePersonalizedAdvertising').js
```

If the result is not **false**, this is a finding.

Remediation Description

Perform the following to configure the system to meet the requirements:

Create a configuration profile containing the following keys in the (com.apple.applicationaccess) payload type:

```
<key>allowApplePersonalizedAdvertising</key>
<false/>
```

ID	system_settings_personalized_advertising_disable	
References	800-53r5	• AC-20 • CM-7, CM-7(1) • SC-7(10)
	CCE	• CCE-95390-1

9.29. Disable Remote Apple Events

If the system does not require Remote Apple Events, support for Apple Remote Events is non-essential and *MUST* be disabled.

The information system *MUST* be configured to provide only essential capabilities. Disabling Remote Apple Events helps prevent the unauthorized connection of devices, the unauthorized transfer of information, and unauthorized tunneling.

To check the state of the system, run the following command(s):

```
/bin/launchctl print-disabled system | /usr/bin/grep -c '"com.apple.AEServer" =>
disabled'
```

If the result is not **1**, this is a finding.

Remediation Description

Perform the following to configure the system to meet the requirements:

```
/usr/sbin/systemsetup -setremoteappleevents off
```

```
/bin/launchctl disable system/com.apple.AEServer
```



Systemsetup with -setremoteappleevents flag will fail unless you grant Full Disk Access to systemsetup or its parent process. Requires supervision.

ID	system_settings_rae_disable	
References	800-53r5	• AC-17 • AC-3
	CCE	• CCE-95392-7

9.30. Disable Screen Sharing and Apple Remote Desktop

Support for both Screen Sharing and Apple Remote Desktop (ARD) is non-essential and *MUST* be disabled.

The information system *MUST* be configured to provide only essential capabilities. Disabling screen sharing and ARD helps prevent the unauthorized connection of devices, the unauthorized transfer of information, and unauthorized tunneling.

To check the state of the system, run the following command(s):

```
result="FAIL"
enabled=$(/bin/launchctl print-disabled system | /usr/bin/grep
'"com.apple.screensharing" => enabled')
running=$(/bin/launchctl print system/com.apple.screensharing 2>/dev/null)

if [[ -z "$running" ]] && [[ -z "$enabled" ]]; then
    result="PASS"
elif [[ -n "$running" ]]; then
    result=result+" RUNNING"
elif [[ -n "$enabled" ]]; then
    result=result+" ENABLED"
fi
echo $result
```

If the result is not **PASS**, this is a finding.

Remediation Description

Perform the following to configure the system to meet the requirements:

```
/bin/launchctl bootout system/com.apple.screensharing
```



```
/bin/launchctl disable system/com.apple.screensharing
```

NOTE - This will apply to the whole system

ID	system_settings_screen_sharing_disable	
References	800-53r5	• AC-17 • AC-3
	CCE	• CCE-95394-3

9.31. Enforce Session Lock After Screen Saver is Started

A screen saver *MUST* be enabled and the system *MUST* be configured to require a password to unlock once the screensaver has been on for a maximum of 5 seconds.

An unattended system with an excessive grace period is vulnerable to a malicious user.

To check the state of the system, run the following command(s):

```
/usr/bin/osascript -l JavaScript << EOS
function run() {
    let delay = ObjC.unwrap(
$.NSUserDefaults.alloc.initWithSuiteName('com.apple.screensaver')\
.objectForKey('askForPasswordDelay'))
    if ( delay <= 5 ) {
        return("true")
    } else {
        return("false")
    }
}
EOS
```

If the result is not **true**, this is a finding.

Remediation Description

Perform the following to configure the system to meet the requirements:

Create a configuration profile containing the following keys in the (com.apple.screensaver) payload type:

```
<key>askForPasswordDelay</key>
<integer>5</integer>
```

ID	system_settings_screensaver_ask_for_password_delay_enforce	
References	800-53r5	• AC-11
	CCE	• CCE-95395-0

9.32. Enforce Screen Saver Password

Users *MUST* authenticate when unlocking the screen saver.

The screen saver acts as a session lock and prevents unauthorized users from accessing the current user's account.

To check the state of the system, run the following command(s):

```
/usr/bin/osascript -l JavaScript << EOS
$.NSUserDefaults.alloc.initWithSuiteName('com.apple.screensaver')\
.objectForKey('askForPassword').js
EOS
```

If the result is not **true**, this is a finding.

Remediation Description

Perform the following to configure the system to meet the requirements:

Create a configuration profile containing the following keys in the (com.apple.screensaver) payload type:

```
<key>askForPassword</key>
<true/>
```

ID	system_settings_screensaver_password_enforce	
References	800-53r5	• AC-11
	CCE	• CCE-95396-8

9.33. Enforce Screen Saver Timeout

The screen saver timeout *MUST* be set to 1200 seconds or a shorter length of time.

This rule ensures that a full session lock is triggered within no more than 1200 seconds of inactivity.

To check the state of the system, run the following command(s):

```

/usr/bin/osascript -l JavaScript << EOS
function run() {
    let timeout = ObjC.unwrap(
$.NSUserDefaults.alloc.initWithSuiteName('com.apple.screensaver')\
.objectForKey('idleTime'))
    if ( timeout <= 1200 ) {
        return("true")
    } else {
        return("false")
    }
}
EOS

```

If the result is not **true**, this is a finding.

Remediation Description

Perform the following to configure the system to meet the requirements:

Create a configuration profile containing the following keys in the (com.apple.screensaver) payload type:

```

<key>idleTime</key>
<integer>1200</integer>

```

ID	system_settings_screensaver_timeout_enforce	
References	800-53r5	• AC-11 • IA-11
	CCE	• CCE-95397-6

9.34. Disable Siri

Support for Siri is non-essential and *MUST* be disabled.

The information system *MUST* be configured to provide only essential capabilities.

To check the state of the system, run the following command(s):

```

/usr/bin/osascript -l JavaScript << EOS
$.NSUserDefaults.alloc.initWithSuiteName('com.apple.applicationaccess')\
.objectForKey('allowAssistant').js
EOS

```

If the result is not **false**, this is a finding.

Remediation Description

Perform the following to configure the system to meet the requirements:

Create a configuration profile containing the following keys in the (com.apple.applicationaccess) payload type:

```
<key>allowAssistant</key>
<false/>
```

ID	system_settings_siri_disable	
References	800-53r5	• AC-20 • CM-7, CM-7(1) • SC-7(10)
	CCE	• CCE-95398-4

9.35. Disable Server Message Block Sharing

Support for Server Message Block (SMB) file sharing is non-essential and *MUST* be disabled.

The information system *MUST* be configured to provide only essential capabilities.

To check the state of the system, run the following command(s):

```
/bin/launchctl print-disabled system | /usr/bin/grep -c '"com.apple.smbd" => disabled'
```

If the result is not **1**, this is a finding.

Remediation Description

Perform the following to configure the system to meet the requirements:

```
/bin/launchctl disable system/com.apple.smbd
```

The system may need to be restarted for the update to take effect.

ID	system_settings_smbd_disable
----	------------------------------

References	800-53r5	• AC-17 • AC-3
	CCE	• CCE-95401-6

9.36. Ensure Software Update is Updated and Current

Make sure Software Update is updated and current.

[Update macOS on Mac](#) or if enrolled in an MDM consult your MDM's documentation for automated methods.

To check the state of the system, run the following command(s):

```
softwareupdate_date_epoch=$(/bin/date -j -f "%Y-%m-%d" "$( /usr/bin/defaults read /Library/Preferences/com.apple.SoftwareUpdate.plist LastFullSuccessfulDate | /usr/bin/awk '{print $1}' )" "+%s")
thirty_days_epoch=$(/bin/date -v -30 "+%s")
if [[ $softwareupdate_date_epoch -lt $thirty_days_epoch ]]; then
  /bin/echo "0"
else
  /bin/echo "1"
fi
```

If the result is not 1, this is a finding.

Remediation Description

Perform the following to configure the system to meet the requirements:

 See discussion on how to install software updates.

ID	system_settings_softwareupdate_current	
References	800-53r5	• SI-2
	CCE	• CCE-95405-7

9.37. Enable SSH Server for Remote Access Sessions

Remote access sessions *MUST* use encrypted methods to protect unauthorized individuals from gaining access.

To check the state of the system, run the following command(s):

```
/bin/launchctl print-disabled system | /usr/bin/grep -c '"com.openssh.sshd" =>
```

```
enabled'
```

If the result is not 1, this is a finding.

Remediation Description

Perform the following to configure the system to meet the requirements:

```
/bin/launchctl enable system/com.openssh.sshd
```

ID	system_settings_ssh_enable	
References	800-53r5	• AC-17 • AC-3 • CM-7, CM-7(1) • IA-2(8)
	CCE	• CCE-95407-3

9.38. Require Administrator Password to Modify System-Wide Preferences

The system *MUST* be configured to require an administrator password in order to modify the system-wide preferences in System Settings.

Some Preference Panes in System Settings contain settings that affect the entire system. Requiring a password to unlock these system-wide settings reduces the risk of a non-authorized user modifying system configurations.

To check the state of the system, run the following command(s):

```
authDBs=("system.preferences" "system.preferences.energysaver"
"system.preferences.network" "system.preferences.printing"
"system.preferences.sharing" "system.preferences.softwareupdate"
"system.preferences.startupdisk" "system.preferences.timemachine")
result="1"
for section in ${authDBs[@]}; do
    if [[ $(/usr/bin/security -q authorizationdb read "$section" | /usr/bin/xmllint
-xpath 'name(//*[contains(text(), "shared")]/following-sibling::*[1])' -) != "false"
]]; then
        result="0"
    fi
    if [[ $(/usr/bin/security -q authorizationdb read "$section" | /usr/bin/xmllint
-xpath '//*[contains(text(), "group")]/following-sibling::*[1]/text()' -) != "admin"
]]; then
```

```

    result="0"
fi
if [[ $(/usr/bin/security -q authorizationdb read "$section" | /usr/bin/xmllint
-xpath 'name(//*[contains(text(), "authenticate-user")]/following-sibling::*[1])' -)
!= "true" ]]; then
    result="0"
fi
if [[ $(/usr/bin/security -q authorizationdb read "$section" | /usr/bin/xmllint
-xpath 'name(//*[contains(text(), "session-owner")]/following-sibling::*[1])' -) !=
"false" ]]; then
    result="0"
fi
done
echo $result

```

If the result is not 1, this is a finding.

Remediation Description

Perform the following to configure the system to meet the requirements:

```

authDBs=("system.preferences" "system.preferences.energysaver"
"system.preferences.network" "system.preferences.printing"
"system.preferences.sharing" "system.preferences.softwareupdate"
"system.preferences.startupdisk" "system.preferences.timemachine")

for section in ${authDBs[@]}; do
    /usr/bin/security -q authorizationdb read "$section" > "/tmp/$section.plist"

    class_key_value=$(/usr/libexec/PlistBuddy -c "Print :class" "/tmp/
$section.plist" 2>&1)
    if [[ "$class_key_value" == *"Does Not Exist"* ]]; then
        /usr/libexec/PlistBuddy -c "Add :class string user" "/tmp/$section.plist"
    else
        /usr/libexec/PlistBuddy -c "Set :class user" "/tmp/$section.plist"
    fi

    key_value=$(/usr/libexec/PlistBuddy -c "Print :shared" "/tmp/$section.plist"
2>&1)
    if [[ "$key_value" == *"Does Not Exist"* ]]; then
        /usr/libexec/PlistBuddy -c "Add :shared bool false" "/tmp/$section.plist"
    else
        /usr/libexec/PlistBuddy -c "Set :shared false" "/tmp/$section.plist"
    fi

    auth_user_key=$(/usr/libexec/PlistBuddy -c "Print :authenticate-user"
"/tmp/$section.plist" 2>&1)
    if [[ "$auth_user_key" == *"Does Not Exist"* ]]; then
        /usr/libexec/PlistBuddy -c "Add :authenticate-user bool true" "/tmp/

```

```

$section.plist"
else
  /usr/libexec/PlistBuddy -c "Set :authenticate-user true" "/tmp/$section.plist"
fi

session_owner_key=$(/usr/libexec/PlistBuddy -c "Print :session-owner"
"/tmp/$section.plist" 2>&1)
if [[ "$session_owner_key" == *"Does Not Exist"* ]]; then
  /usr/libexec/PlistBuddy -c "Add :session-owner bool false" "/tmp/
$section.plist"
else
  /usr/libexec/PlistBuddy -c "Set :session-owner false" "/tmp/$section.plist"
fi

group_key=$(/usr/libexec/PlistBuddy -c "Print :group" "/tmp/$section.plist"
2>&1)
if [[ "$group_key" == *"Does Not Exist"* ]]; then
  /usr/libexec/PlistBuddy -c "Add :group string admin" "/tmp/$section.plist"
else
  /usr/libexec/PlistBuddy -c "Set :group admin" "/tmp/$section.plist"
fi

/usr/bin/security -q authorizationdb write "$section" < "/tmp/$section.plist"
done

```

ID	system_settings_system_wide_preferences_configure	
References	800-53r5	• AC-6, AC-6(1), AC-6(2)
	CCE	• CCE-95408-1

9.39. Configure macOS to Use an Authorized Time Server

Approved time server *MUST* be the only server configured for use. As of macOS 10.13 only one time server is supported.

This rule ensures the uniformity of time stamps for information systems with multiple system clocks and systems connected over a network.

To check the state of the system, run the following command(s):

```

/usr/bin/osascript -l JavaScript << EOS
$.NSUserDefaults.alloc.initWithSuiteName('com.apple.MCX')\
.objectForKey('timeServer').js
EOS

```


If the result is not **time.nist.gov**, this is a finding.

Remediation Description

Perform the following to configure the system to meet the requirements:

Create a configuration profile containing the following keys in the (com.apple.MCX) payload type:

```
<key>timeServer</key>
<string>time.nist.gov</string>
```

ID	system_settings_time_server_configure	
References	800-53r5	• AU-12(1) • SC-45(1)
	CCE	• CCE-95411-5

9.40. Enforce macOS Time Synchronization

Time synchronization *MUST* be enforced on all networked systems.

This rule ensures the uniformity of time stamps for information systems with multiple system clocks and systems connected over a network.

To check the state of the system, run the following command(s):

```
/usr/bin/osascript -l JavaScript << EOS
$.NSUserDefaults.alloc.initWithSuiteName('com.apple.timed')\
.objectForKey('TMAutomaticTimeOnlyEnabled').js
EOS
```

If the result is not **true**, this is a finding.

Remediation Description

Perform the following to configure the system to meet the requirements:



The following settings are in the (com.apple.ManagedClient.preferences) payload. This payload requires the additional settings to be sub-payloads within, containing their defined payload types.

Create a configuration profile containing the following keys in the (com.apple.timed) payload type:

```
<key>TMAutomaticTimeOnlyEnabled</key>
<true/>
```

ID	system_settings_time_server_enforce	
References	800-53r5	• AU-12(1) • SC-45(1)
	CCE	• CCE-95412-3

9.41. Disable TouchID for Unlocking the Device

TouchID enables the ability to unlock a Mac system with a user's fingerprint.

TouchID *MUST* be disabled for "Unlocking your Mac" on all macOS devices that are capable of using Touch ID.

The system *MUST* remain locked until the user establishes access using an authorized identification and authentication method.



TouchID is not an approved biometric authenticator for US Federal Government usage as it has not been verified to meet the strength requirements outlined in NIST SP 800-63.

To check the state of the system, run the following command(s):

```
/usr/bin/osascript -l JavaScript << EOS
$.NSUserDefaults.alloc.initWithSuiteName('com.apple.applicationaccess')\
.objectForKey('allowFingerprintForUnlock').js
EOS
```

If the result is not **false**, this is a finding.

Remediation Description

Perform the following to configure the system to meet the requirements:

Create a configuration profile containing the following keys in the (com.apple.applicationaccess) payload type:

```
<key>allowFingerprintForUnlock</key>
<false/>
```

ID	system_settings_touchid_unlock_disable	
References	800-53r5	• IA-5
	CCE	• CCE-95415-6